BỘ GIÁO DỤC VÀ ĐÀO TẠO

TRƯỜNG ĐẠI HỌC GIA ĐỊNH

KHOA CÔNG NGHỆ THÔNG TIN

TIỂU LUẬN

NGHIÊN CỨU CƠ SỞ LÝ THUYẾT HỆ THỐNG PKI VÀ TRIỂN KHAI ỨNG DỤNG PKI VÀO BẢO MẬT THƯ ĐIỆN TỬ S/MIME

MÔN: CHỨNG THỰC ĐIỆN TỬ

Ngành: **CÔNG NGHỆ THÔNG TIN**

Chuyên ngành (*nếu có*): **AN TOÀN THÔNG TIN**

Giảng viên hướng dẫn: **Th.S VÕ ĐÀO THỊ HỒNG TUYẾT**

Nhóm sinh viên thực hiện: **Nhóm 7**

PHẠM VŨ GIA HUY 23130021

NGUYỄN LÊ HẢI ĐĂNG 23010129

NGUYỄN NGỌC TÚ 23150363

TRẦN HỮU ĐẠT 23150041

Lớp: **020100115702**

TP. Hồ Chí Minh, tháng 12 năm 2025

TRƯỜNG ĐẠI HỌC GIA ĐỊNH
KHOA CÔNG NGHỆ THÔNG TIN

CỘNG HÒA XÃ HỘI CHỦ NGHĨA VIỆT NAM
Độc lập – Tự do – Hạnh phúc

PHIẾU CHẤM BÀI THI TIỂU LUẬN

Tên học phần: Chứng Thực Điện Tử Lớp học phần: 020100115702

Họ và tên sinh viên: Nguyễn Lê Hải Đăng Mã số sinh viên: 23010129

STT	Tiêu chí	Điểm	Ghi chú
1	**Bố cục**		
2	**Hình thức**		
	- Trình bày (font chữ, size chữ; canh lề…)		
	- Kỹ thuật đánh máy, chính tả, hình ảnh có chú thích.		
	- Trích nguồn tài liệu tham khảo		
	Nội dung chính		
	[1]. Tổng quan mật mã học + Mật mã khoá bí mật + Mật mã khoá công khai + Chữ ký số + Hàm băm		
	[2]. Cơ sở hạ tầng khóa công khai + Khái niệm cơ bản về hệ thống PKI + Thực trạng PKI tại Việt Nam + Các định nghĩa về cơ sở hạ tầng khóa công khai + Chức năng các thành phần chính của PKI + Cách thức hoạt động của PKI + Các tiến trình trong PKI		
	[3]. Ứng dụng của PKI + Giới thiệu về ứng dụng của PKI + Ứng dụng của PKI vào…		
	[4]. Thực nghiệm		
Tổng điểm			

Tp. HCM, ngày 26 tháng 12 năm 2025
Giảng viên

Võ Đào Thị Hồng Tuyết

LỜI CẢM ƠN

Chúng em xin gửi lời cảm ơn chân thành và sự tri ân sâu sắc đối với các thầy cô của trường Đại học Gia Định , đặc biệt là các thầy cô khoa Công Nghệ Thông Tin của trường đã tận tình giảng dạy và trang bị cho em những kiến thức nền tảng trong suốt quá trình học tập tại khoa để có thêm nhiều kinh nghiệm cho tương lai. Và em cũng xin chân thành cám ơn cô Võ Đào Thị Hồng Tuyết đã nhiệt tình hướng dẫn hướng dẫn chỉ bảo em trong quá trình thực hiện đề tài. Trong quá trình học tập, cũng như là trong quá trình làm đồ án, nhóm em khó tránh khỏi sai sót, rất mong Cô bỏ qua. Đồng thời do trình độ lý luận cũng như kinh nghiệm thực tiễn còn hạn chế nên bài báo cáo không thể tránh khỏi những thiếu sót, em rất mong nhận được ý kiến đóng góp từ Cô, để em học thêm được nhiều kinh nghiệm và sẽ hoàn thành tốt hơn ở bài báo cáo môn học sắp tới

Chúng em xin chân thành cảm ơn!

MỤC LỤC

CHƯƠNG I: TỔNG QUAN MẬT MÃ HỌC **6**
1.1. Cơ bản về An toàn thông tin **6**
1.1.1 Mật mã khóa bí mật 7
1.1.2. Mật mã khóa công khai 10
1.1.3. So sánh khóa đối xứng – bất đối xứng 15
1.2. Chữ ký số **16**
1.3. Hàm băm **18**
CHƯƠNG II: CƠ SỞ HẠ TẦNG KHÓA CÔNG KHAI **22**
2.1. Khái niệm cơ bản về hệ thống PKI **22**
2.2. Thực trạng PKI tại Việt Nam **24**
2.3. Định nghĩa về cơ sở hạ tầng khóa công khai **26**
2.4. Chức năng các thành phần chính của PKI **27**
2.5. Cách thức hoạt động của PKI **29**
2.5.1. Cơ chế cặp khóa (Key Pair Mechanism) 29
2.5.2. Chuỗi tin cậy (Chain of Trust) 30
2.6. Các tiến trình trong PKI **30**
2.6.1. Tiến trình Đăng ký và Cấp phát (Enrollment Process) 31
2.6.2. Tiến trình Xác thực Chứng thư (Certificate Validation Process) 31
2.6.3. Tiến trình Thu hồi (Revocation Process) 32
2.6.4. Tiến trình Gia hạn và Phục hồi (Renewal & Recovery) 32
CHƯƠNG III: ỨNG DỤNG CỦA PKI **33**
Ứng dụng của PKI vào S/MIME **33**
CHƯƠNG IV: KẾT LUẬN & HƯỚNG PHÁT TRIỂN **51**
4.1. Kết luận **51**
4.2. Hướng phát triển **52**

Danh mục từ viết tắt

Từ viết tắt	Tên tiếng Anh đầy đủ	Giải nghĩa tiếng Việt
ACME	Automated Certificate Management Environment	Môi trường quản lý chứng thư tự động
AES	Advanced Encryption Standard	Tiêu chuẩn mã hóa tiên tiến
CA	Certificate Authority	Tổ chức cấp phát chứng thư số
CIA	Confidentiality, Integrity, Availability	Tính Bí mật, Toàn vẹn và Sẵn sàng
CRL	Certificate Revocation List	Danh sách thu hồi chứng thư
CSR	Certificate Signing Request	Yêu cầu ký chứng thực
DDoS	Distributed Denial of Service	Tấn công từ chối dịch vụ phân tán
DES	Data Encryption Standard	Tiêu chuẩn mã hóa dữ liệu
DID	Decentralized Identity	Danh tính phi tập trung
ECC	Elliptic Curve Cryptography	Mật mã đường cong Elliptic
HSM	Hardware Security Module	Mô-đun bảo mật phần cứng
IETF	Internet Engineering Task Force	Lực lượng chuyên trách kỹ thuật Internet
IoT	Internet of Things	Internet vạn vật

Từ viết tắt	Tên tiếng Anh đầy đủ	Giải nghĩa tiếng Việt
LDAP	Lightweight Directory Access Protocol	Giao thức truy cập thư mục hạng nhẹ
MD5	Message Digest Algorithm 5	Thuật toán tóm tắt thông điệp 5
MFA	Multi-Factor Authentication	Xác thực đa yếu tố
MitM	Man-in-the-Middle	Tấn công xen giữa (người đứng giữa)
NEAC	National Electronic Authentication Centre	Trung tâm Chứng thực điện tử quốc gia
OCSP	Online Certificate Status Protocol	Giao thức trạng thái chứng thư trực tuyến
PKI	Public Key Infrastructure	Cơ sở hạ tầng khóa công khai
PQC	Post-Quantum Cryptography	Mật mã hậu lượng tử
RA	Registration Authority	Cơ quan đăng ký
RSA	Rivest–Shamir–Adleman	Thuật toán mã hóa RSA
SHA	Secure Hash Algorithm	Thuật toán băm an toàn
S/MIME	Secure/Multipurpose Internet Mail Extensions	Tiêu chuẩn bảo mật thư điện tử

Từ viết tắt	Tên tiếng Anh đầy đủ	Giải nghĩa tiếng Việt
SSL/TLS	Secure Sockets Layer / Transport Layer Security	Giao thức bảo mật lớp vận chuyển
VA	Validation Authority	Cơ quan xác thực
VGCA	Vietnam Government Certification Authority	Hệ thống Chứng thực chữ ký số chuyên dùng Chính phủ

Danh mục hình ảnh

Hình 3.1: Cấu hình thư mục làm việc và file openssl.cnf trên Command Prompt .
Hình 3.2: Câu lệnh tạo khóa bí mật (Private Key) cho người gửi .
Hình 3.3: Câu lệnh tạo yêu cầu chứng thực (CSR) chứa thông tin Email .
Hình 3.4: Quá trình CA ký phát hành chứng thư số .
Hình 3.5: Xuất chứng thư số và khóa bí mật ra định dạng .P12 .
Hình 3.6: Giao diện cài đặt (Settings) trên phần mềm Mozilla Thunderbird .
Hình 3.7: Giao diện Trình quản lý chứng thư (Certificate Manager) .
Hình 3.8: Nhập (Import) Root CA vào danh sách tin cậy .
Hình 3.9: Hộp thoại xác nhận tin cậy CA cho xác thực website và email .
Hình 3.10: Yêu cầu nhập mật khẩu bảo vệ khi nhập file chứng thư .P12 .
Hình 3.11: Chứng thư số cá nhân đã được nhập thành công vào Thunderbird .
Hình 3.12: Giao diện Cài đặt tài khoản (Account Settings) .
Hình 3.13: Cấu hình Mã hóa đầu cuối (End-To-End Encryption) .
Hình 3.14: Chọn chứng thư số dùng để ký và mã hóa .
Hình 3.15: Hộp thoại xác nhận sử dụng cùng một chứng thư cho mã hóa và giải mã .
Hình 3.16: Giao diện soạn thảo email với tùy chọn Ký số (Digitally Sign) .
Hình 3.17: Quá trình gửi email đã ký số .
Hình 3.18: Cảnh báo "Chữ ký điện tử không hợp lệ" trên máy người nhận khi chưa tin cậy CA .
Hình 3.19: Hộp thoại nhập và tin cậy Root CA trên máy người nhận .
Hình 3.20: Thông báo thư đã được ký hợp lệ sau khi thiết lập tin cậy .

Hình 3.21: Chi tiết bảo mật thư (Message Security) hiển thị thông tin người ký .
Hình 3.22: Mã nguồn email (định dạng MIME) trước khi bị chỉnh sửa .
Hình 3.23: Quá trình can thiệp sửa đổi nội dung bản tin (Tampering) bằng Notepad .
Hình 3.24: Cảnh báo "Chữ ký số không hợp lệ" (Digital Signature Is Not Valid) sau khi nội dung bị thay đổi .

CHƯƠNG I: TỔNG QUAN MẬT MÃ HỌC

1.1. Cơ bản về An toàn thông tin

Trong kỷ nguyên số, khi dữ liệu được coi là tài sản dầu mỏ mới, an toàn thông tin (Information Security - InfoSec) không chỉ đơn thuần là việc cài đặt phần mềm diệt virus hay thiết lập mật khẩu. Đó là một chiến lược quản trị rủi ro toàn diện nhằm bảo vệ thông tin và hệ thống thông tin khỏi các mối đe dọa ngày càng tinh vi như tấn công mạng, gián điệp kinh tế, và phá hoại hệ thống.

Mục tiêu cốt lõi của an toàn thông tin luôn xoay quanh mô hình CIA Triad (Tam giác CIA). Đây là tiêu chuẩn vàng để đánh giá mức độ an toàn của bất kỳ hệ thống nào.

Tính bí mật (Confidentiality)

Đây là khía cạnh thường được nghĩ đến đầu tiên khi nhắc tới bảo mật. Mục tiêu là ngăn chặn việc tiết lộ thông tin nhạy cảm cho các thực thể không được phép (bao gồm con người, chương trình máy tính, hoặc quy trình).

- Cơ chế thực hiện:

+ Mã hóa (Encryption): Chuyển đổi dữ liệu sang dạng không thể đọc hiểu nếu không có khóa giải mã (ví dụ: mã hóa dữ liệu trên ổ cứng hoặc đường truyền SSL/TLS).

+ Kiểm soát truy cập (Access Control): Áp dụng xác thực đa yếu tố (MFA) và quét sinh trắc học.

+ Phân loại dữ liệu: Gán nhãn dữ liệu (Công khai, Nội bộ, Tuyệt mật) để áp dụng các chính sách bảo vệ tương ứng.

- Mối đe dọa: Tấn công nghe lén (Sniffing), tấn công Man-in-the-Middle (MitM), hoặc kỹ nghệ xã hội (Social Engineering) để đánh cắp mật khẩu.

Tính Toàn vẹn (Integrity)

Tính toàn vẹn đảm bảo rằng dữ liệu chính xác, đáng tin cậy và không bị thay đổi sai lệch so với trạng thái ban đầu, dù là do tai nạn hay do ác ý.

- Cơ chế thực hiện:

+ Hàm băm (Hashing): Sử dụng các thuật toán như SHA-256 để tạo ra "dấu vân tay" số cho tệp tin. Nếu tệp bị thay đổi dù chỉ một bit, mã băm sẽ thay đổi hoàn toàn.

+ Chữ ký số (Digital Signature): Xác nhận nguồn gốc và đảm bảo văn bản không bị chỉnh sửa trên đường truyền.

+ Kiểm soát phiên bản: Ghi lại lịch sử thay đổi để có thể khôi phục lại trạng thái đúng đắn trước đó.

- Mối đe dọa: Tiêm nhiễm mã độc (như virus thay đổi file hệ thống), tấn công SQL Injection làm sai lệch cơ sở dữ liệu.

Tính Sẵn sàng (Availability)

Dữ liệu dù được bảo mật và toàn vẹn nhưng nếu người dùng không thể truy cập khi cần thì hệ thống đó vẫn bị coi là thất bại. Tính sẵn sàng đảm bảo hệ thống hoạt động liên tục và ổn định.

- Cơ chế thực hiện:

+ Dự phòng (Redundancy): Sử dụng các hệ thống máy chủ dự phòng (Failover cluster) và sao lưu dữ liệu (Backup) định kỳ (quy tắc 3-2-1).

+ Cân bằng tải (Load Balancing): Phân phối lưu lượng truy cập để tránh quá tải một điểm.

+ Kế hoạch phục hồi thảm họa (Disaster Recovery Plan): Quy trình khôi phục hệ thống sau sự cố vật lý hoặc tấn công mạng.

- Mối đe dọa: Tấn công từ chối dịch vụ (DDoS), mã độc tống tiền (Ransomware) mã hóa dữ liệu khiến người dùng không thể truy cập, hoặc sự cố phần cứng/mất điện.

1.1.1 Mật mã khóa bí mật

Mật mã khóa bí mật (hay còn gọi là mật mã đối xứng) là phương pháp mã hóa lâu đời và phổ biến nhất trong lịch sử, từ thời La Mã cổ đại (Mã Caesar) cho đến các hệ thống ngân hàng hiện đại. Nguyên tắc nền tảng của nó là sự chia sẻ niềm tin: cả hai bên tham gia giao tiếp phải sở hữu cùng một chìa khóa để khóa và mở dữ liệu.

Nguyên lý hoạt động

Khác với tư duy thông thường, mật mã đối xứng hiện đại không chỉ đơn thuần là thay thế ký tự này bằng ký tự khác. Nó dựa trên hai kỹ thuật toán học chính:

- Thay thế (Substitution): Thay đổi các bit dữ liệu bằng các bit khác theo quy tắc.

- Hoán vị (Permutation/Transposition): Xáo trộn vị trí của các bit dữ liệu.

Quy trình toán học được mô tả như sau:

Giả sử P là bản rõ (Plaintext), C là bản mã (Ciphertext), và K là khóa bí mật (Secret Key).

- Mã hóa (Encryption - E): $C = E_{K(P)}$

- Giải mã (Decryption - D): $P = D_{K(C)}$

Yêu cầu cốt tử: Thuật toán mã hóa (E) có thể được công khai (theo nguyên tắc Kerckhoffs), nhưng Khóa (K) phải được giữ bí mật tuyệt đối. Nếu K bị lộ, toàn bộ dữ liệu C sẽ bị giải mã ngay lập tức.

Các thuật toán phổ biến

DES (Data Encryption Standard)

Về mặt lịch sử, thuật toán DES (Data Encryption Standard) được phát triển bởi IBM và chính thức được chính phủ Mỹ lựa chọn làm tiêu chuẩn vào năm 1977. Xét về cấu trúc kỹ thuật, hệ thống này hoạt động dựa trên việc xử lý các khối dữ liệu 64-bit kết hợp với độ dài khóa là 56-bit.

Tuy nhiên, ở thời điểm hiện tại, DES đã bị coi là lỗi thời và không còn an toàn. Nguyên nhân chính dẫn đến cái chết của thuật toán này nằm ở độ dài khóa 56-bit khá khiêm tốn, chỉ tạo ra không gian khóa giới hạn với 2^{56} trường hợp. Với sức mạnh xử lý vượt trội của phần cứng máy tính ngày nay, các hacker hoàn toàn có thể thực hiện tấn công vét cạn (brute-force) để dò tìm ra khóa giải mã chỉ trong vòng vài giờ đồng hồ.

3DES (Triple DES)

Để khắc phục nhược điểm cốt tử là độ dài khóa quá ngắn của chuẩn DES cũ, người ta đã áp dụng cơ chế thực hiện quy trình DES ba lần liên tiếp lên cùng một khối dữ liệu. Quy trình này tuân theo trình tự cụ thể: Mã hóa (với khóa K1) -> Giải mã (với khóa K2) -> Mã hóa (với khóa K3).

Mặc dù phương pháp này mang lại mức độ an toàn cao hơn so với DES nguyên bản, nhưng nó lại đánh đổi bằng hiệu suất hệ thống, trở nên rất chậm chạp do thuật toán phải vận hành đến ba lần cho mỗi tác vụ. Bên cạnh đó, việc vẫn duy trì kích thước khối dữ liệu nhỏ (chỉ 64-bit) khiến 3DES tồn tại lỗ hổng nguy hiểm trước các dạng tấn công va chạm (collision attacks), mà điển hình là tấn công Sweet32.

AES (Advanced Encryption Standard)

Về nguồn gốc, thuật toán AES (Advanced Encryption Standard) được phát triển bởi hai nhà mật mã học người Bỉ là Joan Daemen và Vincent Rijmen, do đó ban đầu nó còn được biết đến với tên gọi là thuật toán Rijndael. Về cơ chế hoạt động, đây là một

hệ thống mã hóa khối (block cipher) vận hành trên các khối dữ liệu có kích thước 128-bit.

Điểm linh hoạt của AES nằm ở độ dài khóa đa dạng với ba mức: 128, 192 hoặc 256 bit, tùy thuộc vào nhu cầu bảo mật. Trong đó, phiên bản AES-128 được đánh giá là đủ mạnh cho hầu hết các giao dịch thương mại thông thường, còn phiên bản AES-256 được sử dụng đặc biệt cho các tài liệu Tối mật của chính phủ và quân đội.

Không chỉ an toàn, AES còn sở hữu ưu điểm vượt trội nhờ thiết kế toán học cực kỳ hiệu quả. Kiến trúc này cho phép thuật toán đạt tốc độ xử lý rất nhanh trên cả phần mềm lẫn phần cứng, đặc biệt được tối ưu hóa nhờ tập lệnh AES-NI hỗ trợ xử lý trực tiếp trên các dòng chipset hiện đại của Intel và AMD.

Các thuật toán khác

Các giải pháp thay thế và bổ trợ cho AES

Bên cạnh chuẩn AES phổ biến, thế giới mật mã còn tồn tại các thuật toán mạnh mẽ khác phục vụ cho những nhu cầu chuyên biệt:

- Blowfish và Twofish: Đây là những lựa chọn thay thế xuất sắc cho AES với đặc tính mã nguồn mở, cho phép cộng đồng kiểm định tính an toàn một cách minh bạch.

- ChaCha20: Khác với AES là mã hóa khối, ChaCha20 là một thuật toán mã hóa dòng stream cipher hiện đại. Ưu điểm lớn nhất của nó là tốc độ xử lý cực nhanh trên các thiết bị di động vốn không được tích hợp phần cứng hỗ trợ giải mã AES chuyên dụng. Hiện nay, Google thường xuyên sử dụng ChaCha20 để bảo vệ kết nối HTTPS trên nền tảng Android.

Đánh giá tổng quan về Mã hóa đối xứng

Về ưu điểm (Hiệu suất và Dung lượng):

Mã hóa đối xứng sở hữu hiệu suất cực cao do các phép toán đơn giản hơn rất nhiều so với mã hóa bất đối xứng (như RSA hay ECC). Chính vì vậy, đây là lựa chọn duy nhất khả thi để mã hóa các luồng dữ liệu thời gian thực (như streaming video, cuộc gọi VoIP) hoặc bảo vệ các kho dữ liệu lớn (ổ cứng máy chủ, cơ sở dữ liệu). Ngoài ra, kích thước bản mã sau khi xử lý gần như tương đương với bản rõ ban đầu, giúp tiết kiệm băng thông và dung lượng lưu trữ.

Về nhược điểm (Thách thức trong vận hành):

Tuy nhiên, mã hóa đối xứng đối mặt với hai vấn đề nan giải:

- Vấn đề phân phối khóa (Key Distribution Problem): Để trao đổi tin mật, người gửi (A) và người nhận (B) bắt buộc phải có cùng một khóa K. Thách thức nằm ở việc làm sao chuyển khóa K này cho nhau một cách an toàn. Nếu gửi qua Internet (email/chat), hacker có thể đánh cắp; nếu gặp mặt trực tiếp thì lại bất khả thi trong bối cảnh kết nối toàn cầu.

- Khả năng mở rộng kém (Scalability): Trong một mạng lưới cần liên lạc bảo mật đôi một giữa n người dùng, mỗi cặp sẽ cần một khóa riêng biệt. Số lượng khóa cần quản lý sẽ tăng theo công thức: n(n-1)/2. Ví dụ thực tế, một công ty chỉ với 1.000 nhân viên sẽ phải quản lý tới 499.500 khóa bí mật khác nhau. Đây thực sự được xem là một cơn ác mộng về mặt quản trị hệ thống.

1.1.2. Mật mã khóa công khai

Khác với mật mã đối xứng (nơi hai bên phải quen biết và tin tưởng nhau từ trước để trao đổi khóa), mật mã khóa công khai cho phép hai người hoàn toàn xa lạ có thể thiết lập một kênh giao tiếp an toàn ngay lập tức.

Nguyên lý hoạt động

Hệ thống này dựa trên các hàm toán học một chiều (Trapdoor functions) - dễ tính xuôi nhưng cực khó tính ngược. Mỗi người dùng trong hệ thống sẽ sở hữu một cặp chìa khóa (Key Pair) được sinh ra đồng thời:

- Khóa công khai (Public Key): Hãy tưởng tượng đây là một chiếc ổ khóa (padlock) đang mở. Bạn có thể sao chép chiếc ổ khóa này và phát miễn phí cho cả thế giới. Bất kỳ ai cũng có thể dùng nó để khóa một chiếc hộp lại.

- Khóa bí mật (Private Key): Đây là chiếc chìa khóa duy nhất mở được chiếc ổ khóa trên. Bạn phải giữ nó bên mình 24/7 và không cho ai thấy.

Quy trình 1: Đảm bảo tính Bí mật

Mục tiêu: Gửi tin nhắn mà chỉ người nhận đọc được.

1. Bên gửi (Alice): Tìm Khóa công khai của Bob (được niêm yết trên danh bạ hoặc website).

2. Mã hóa: Alice dùng Khóa công khai của Bob để khóa nội dung tin nhắn. C=EPubKey_Bob(M)

3. Truyền tin: Tin nhắn đã mã hóa được gửi đi. Hacker có bắt được cũng vô dụng vì không có chìa khóa giải mã.

4. Bên nhận (Bob): Dùng Khóa bí mật của chính mình để mở khóa. M=DPrivKey_Bob(C)

Lưu ý: Ngay cả Alice sau khi mã hóa xong cũng không thể giải mã lại tin nhắn của chính mình nếu cô ấy không có Khóa bí mật của Bob.

Quy trình 2: Đảm bảo tính Xác thực

Mục tiêu: Chứng minh người gửi chính là chủ nhân của tin nhắn (Chống chối bỏ). Đây là quy trình ngược so với mã hóa.

1. Bên ký (Alice): Dùng Khóa bí mật của mình để xử lý tin nhắn (thường là mã băm của tin nhắn). Đây gọi là tạo chữ ký số.

2. Bên kiểm tra (Bob): Dùng Khóa công khai của Alice để giải mã/kiểm tra chữ ký đó.

3. Nguyên lý: Nếu Khóa công khai của Alice mở được gói tin, điều đó chứng tỏ gói tin đó chắc chắn đã được khóa lại bởi Khóa bí mật của Alice. Vì chỉ có Alice mới có Khóa bí mật đó, nên Alice không thể chối bỏ việc mình đã gửi tin.

Các thuật toán phổ biến

RSA (Rivest–Shamir–Adleman)

Về mặt cốt lõi, độ bảo mật của RSA được xây dựng dựa trên cơ sở toán học vững chắc liên quan đến độ khó của bài toán phân tích thừa số nguyên tố. Nguyên lý này hoạt động dựa trên sự bất đối xứng về chi phí tính toán: việc thực hiện phép nhân hai số nguyên tố lớn (P x Q = N) là thao tác rất đơn giản và nhanh chóng. Tuy nhiên, chiều ngược lại—tức là tìm ra hai thừa số P và Q khi chỉ biết trước kết quả N (một số cực lớn)—lại là một thách thức khổng lồ. Với năng lực của các siêu máy tính hiện nay, việc giải quyết bài toán phân tích này có thể tiêu tốn hàng triệu năm, tạo nên một bức tường bảo vệ an toàn cho dữ liệu.

Để đảm bảo khả năng chống lại các cuộc tấn công vét cạn hiện đại, chuẩn RSA ngày nay yêu cầu độ dài khóa tối thiểu phải đạt 2048-bit. Thậm chí, để duy trì mức độ bảo mật cao và lâu dài hơn trước sự phát triển của phần cứng, các chuyên gia thường khuyến nghị sử dụng độ dài khóa lên tới 4096-bit.

Nhờ những đặc tính ưu việt này, RSA trở thành xương sống của bảo mật thông tin hiện đại với các ứng dụng rộng rãi như: tạo lập chữ ký số để xác thực văn bản, mã hóa thư điện tử (tiêu chuẩn PGP), và đóng vai trò then chốt trong giai đoạn bắt tay (handshake) để thiết lập kết nối an toàn cho giao thức SSL/TLS trên Internet.

ECC (Elliptic Curve Cryptography)

Mật mã đường cong Elliptic (ECC - Elliptic Curve Cryptography)

Trong bối cảnh công nghệ hiện đại, ECC nổi lên như một chuẩn mực mới, dần thay thế RSA trong nhiều ứng dụng quan trọng.

- Cơ sở toán học: Khác với RSA dựa trên bài toán phân tích thừa số nguyên tố, ECC xây dựng độ bảo mật dựa trên tính phức tạp của bài toán logarit rời rạc trên đường cong elliptic (với phương trình đại số đặc trưng dạng $y^2 = x^3 + ax + b$).

- Ưu điểm vượt trội: Sức mạnh lớn nhất của ECC nằm ở hiệu suất. Nó cung cấp mức độ an toàn tương đương với RSA nhưng sử dụng kích thước khóa nhỏ hơn rất nhiều. Cụ thể, một khóa ECC 256-bit có độ an toàn ngang ngửa với khóa RSA 3072-bit.

- Ứng dụng thực tiễn: Nhờ khóa ngắn, ECC yêu cầu năng lực tính toán thấp hơn, tiết kiệm băng thông truyền tải và năng lượng pin. Chính vì vậy, ECC được xem là tiêu chuẩn vàng cho các thiết bị di động, mạng lưới vạn vật (IoT) và đặc biệt là công nghệ Blockchain (cả Bitcoin và Ethereum đều sử dụng ECC làm nền tảng).

Phân tích Ưu và Nhược điểm của Mật mã khóa công khai (Asymmetric Cryptography)

Cần khẳng định rằng, mật mã khóa công khai không sinh ra để thay thế hoàn toàn mật mã đối xứng về mặt hiệu năng. Sứ mệnh của nó là giải quyết các vấn đề về quản lý và niềm tin mà mật mã đối xứng không thể thực hiện được.

Ưu điểm (Giải pháp cho các vấn đề kinh điển)

Giải quyết triệt để vấn đề phân phối khóa (Key Distribution)

Đây là ưu điểm mang tính cách mạng nhất.

- Trong mật mã đối xứng, để hai bên giao tiếp an toàn, họ buộc phải tìm một kênh tuyệt mật để trao đổi khóa trước, điều gần như bất khả thi trên mạng Internet rộng lớn.

- Ngược lại, với mật mã công khai, Khóa công khai (Public Key) có thể được chia sẻ rộng rãi qua các kênh không an toàn (như email, website, chat công khai) mà không làm ảnh hưởng đến bảo mật. Kẻ tấn công dù có lấy được Public Key cũng chỉ có thể dùng để mã hóa tin nhắn gửi cho chủ sở hữu, chứ không thể giải mã ngược lại.

Tính Chống chối bỏ (Non-repudiation)

Đây là tính năng độc quyền mà mật mã đối xứng không sở hữu.

- Cơ chế: Khi người gửi (Alice) sử dụng Khóa riêng (Private Key) để tạo chữ ký số, người nhận (Bob) có thể dùng Public Key của Alice để xác thực.

- Hệ quả pháp lý: Nếu phép kiểm tra thành công, về mặt toán học, chỉ có Alice mới có thể tạo ra chữ ký đó. Do vậy, Alice không thể chối cãi hành động của mình (ví dụ: tôi không gửi tin nhắn này). Điều này đóng vai trò cốt yếu trong các giao dịch ngân hàng và hợp đồng điện tử.

Khả năng mở rộng quản lý khóa (Scalability)

Trong các hệ thống mạng lưới lớn, mật mã công khai thể hiện sự vượt trội về khả năng quản trị.

- Giả sử mạng lưới có người dùng:

+ Mật mã đối xứng: Cần tới cặp khóa riêng biệt. Ví dụ: 1.000 người dùng sẽ cần quản lý khoảng 500.000 khóa – một gánh nặng khổng lồ.

+ Mật mã công khai: Chỉ cần khóa (mỗi người giữ 1 Private Key và công bố 1 Public Key). Ví dụ: 1.000 người chỉ cần 2.000 khóa. Điều này giúp giảm tải áp lực quản trị hệ thống một cách đáng kể.

Nhược điểm (Cái giá của sự bảo mật)

Sự tiện lợi và các tính năng bảo mật cao cấp luôn đi kèm với chi phí lớn về tài nguyên.

Hiệu suất thấp (Performance Overhead)

Đây là điểm yếu chí tử khiến mật mã công khai không thể dùng để mã hóa dữ liệu lớn.

- Nguyên nhân: Các thuật toán như RSA hay ECC dựa trên các phép toán số học phức tạp với các số nguyên cực lớn (như lũy thừa modulo, phép nhân điểm trên đường cong). Trong khi đó, AES chỉ dùng các phép toán thao tác bit đơn giản (XOR, dịch bit) nên tốc độ xử lý của CPU rất nhanh.

- Thực tế: Mật mã công khai chậm hơn mật mã đối xứng từ 1.000 đến 10.000 lần.

- Hệ quả: Trong thực tế, không ai dùng RSA để mã hóa cả một bộ phim hay ổ cứng. Người ta sử dụng mô hình lai: Dùng mật mã công khai để mã hóa khóa phiên (session key) của AES, sau đó dùng AES để mã hóa dữ liệu.

Kích thước khóa lớn (Key Size)

Để đạt được cùng một cấp độ an toàn, mật mã công khai thường yêu cầu khóa dài hơn nhiều so với mật mã đối xứng, gây tốn kém băng thông và tài nguyên lưu trữ (đặc biệt trên Smartcards hay thiết bị IoT). Ví dụ: Để đạt độ an toàn tương đương chuẩn 128-bit của AES:

RSA cần khóa dài tới 3072-bit.

ECC đã cải thiện vấn đề này tốt hơn RSA nhưng vẫn cần 256-bit.

Nguy cơ tấn công Man-in-the-Middle (MitM)

Mặc dù mật mã khóa công khai đã loại bỏ được yêu cầu phải bảo mật kênh truyền khóa, song nó lại đặt ra một thách thức nghiêm trọng khác liên quan đến việc bảo mật tính xác thực của chính chiếc khóa đó. Một lỗ hổng chí mạng nảy sinh khi tin tặc thực hiện tấn công xen giữa đường truyền, đánh tráo khóa công khai của một tổ chức uy tín (như ngân hàng) bằng khóa của chính hắn. Hậu quả là người dùng sẽ vô tình mã hóa và gửi dữ liệu nhạy cảm trực tiếp cho kẻ tấn công mà không hề hay biết. Để khắc phục vấn đề niềm tin này, thế giới buộc phải xây dựng một Hạ tầng khóa công khai (PKI) phức tạp với sự tham gia của các Tổ chức chứng thực số (CA). Giải pháp này tuy hiệu quả nhưng lại kéo theo gánh nặng chi phí khổng lồ về vận hành, bảo trì, đồng thời tiềm ẩn rủi ro hệ thống nghiêm trọng nếu chính tổ chức CA bị xâm nhập, mà điển hình là vụ tấn công vào DigiNotar năm 2011 đã gây chấn động giới an ninh mạng toàn cầu.

Bên cạnh các rủi ro về hạ tầng xác thực, nền tảng của mật mã khóa công khai hiện đại còn đang đối mặt với mối đe dọa hiện hữu từ sự trỗi dậy của máy tính lượng tử. Các thuật toán tiêu chuẩn hiện nay như RSA hay ECC đều được thiết kế dựa trên giả định toán học rằng máy tính cổ điển không thể giải quyết các bài toán phân tích thừa số nguyên tố hoặc logarit rời rạc trong thời gian ngắn. Tuy nhiên, sự xuất hiện của thuật toán Shor chạy trên các máy tính lượng tử đủ mạnh trong tương lai hoàn toàn có khả năng phá vỡ các bức tường bảo mật này chỉ trong tích tắc. Chính viễn cảnh này đã buộc

các chính phủ và tổ chức công nghệ lớn phải chạy đua nghiên cứu các chuẩn Mật mã hậu lượng tử (Post-Quantum Cryptography) nhằm đảm bảo an toàn thông tin trước khi kỷ nguyên lượng tử thực sự bắt đầu.

1.1.3. So sánh khóa đối xứng – bất đối xứng

Khi xét về bản chất và cơ chế hoạt động, sự khác biệt căn bản giữa mật mã đối xứng và bất đối xứng bắt nguồn từ chính nền tảng toán học mà chúng được xây dựng. Mật mã đối xứng vận hành dựa trên lý thuyết Hỗn loạn và Khuếch tán (Confusion & Diffusion) của Claude Shannon, sử dụng chủ yếu các phép toán logic bit cấp thấp như XOR, hoán vị hay các hộp thay thế (S-Box). Trong khi đó, mật mã bất đối xứng lại đặt nền móng trên Lý thuyết số (Number Theory) phức tạp, tận dụng độ khó giải của các bài toán toán học kinh điển như phân tích thừa số nguyên tố trong RSA, logarit rời rạc trong Diffie-Hellman hay các tính chất của đường cong Elliptic trong ECC.

Chính sự khác biệt về nền tảng này đã dẫn đến sự phân hóa rõ rệt về độ phức tạp tính toán và hiệu suất. Các thuật toán đối xứng sở hữu độ phức tạp thấp (khoảng On^3) với các phép toán rất nhẹ, cho phép các CPU hiện đại hỗ trợ xử lý trực tiếp thông qua các tập lệnh phần cứng chuyên dụng như AES-NI. Trái ngược hoàn toàn, mật mã bất đối xứng đòi hỏi chi phí tính toán rất cao (thường là $O(n^3)$ hoặc hơn) do hệ thống phải thực hiện các phép tính lũy thừa với những số nguyên cực lớn, có thể lên tới 2048-bit, gây tiêu tốn một lượng lớn chu kỳ xử lý của CPU.

Xét về tính chất hàm số, nếu như mật mã đối xứng sử dụng các hàm song ánh (Bijective function) có thể đảo ngược quy trình dễ dàng khi nắm giữ khóa, thì mật mã bất đối xứng lại hoạt động dựa trên nguyên lý của hàm một chiều cửa sập (Trapdoor function). Loại hàm này có đặc tính đặc biệt là rất dễ dàng khi tính theo chiều xuôi, nhưng việc tính ngược lại là cực kỳ khó khăn, gần như bất khả thi nếu không có thông tin bí mật từ khóa riêng (Private Key).

Tổng thể so sánh

Khi đặt lên bàn cân so sánh tổng thể, sự khác biệt giữa hai loại hình mật mã bắt đầu ngay từ tên gọi và nguyên lý cốt lõi. Mật mã đối xứng, hay còn gọi là Mã hóa khóa bí mật, vận hành dựa trên nguyên tắc bí mật chia sẻ, trong đó các bên tham gia bắt buộc phải sở hữu cùng một khóa duy nhất cho cả quá trình mã hóa lẫn giải mã. Ngược lại, mật mã bất đối xứng được biết đến là Mã hóa khóa công khai, hoạt động dựa trên niềm

tin công khai với cơ chế sử dụng cặp khóa riêng biệt: một khóa công khai (Public Key) để mã hóa và một khóa bí mật (Private Key) để giải mã.

Về mặt hiệu năng và đặc tính kỹ thuật, mật mã đối xứng thể hiện ưu thế vượt trội về tốc độ xử lý nhờ sử dụng các phép toán bit đơn giản như XOR hay hoán vị, đi kèm với kích thước khóa nhỏ gọn (như AES-128 bit) giúp tiết kiệm tài nguyên. Trái lại, mật mã bất đối xứng có tốc độ chậm hơn khoảng 1000 lần do phải xử lý các thuật toán toán học phức tạp như lũy thừa số lớn hay đường cong Elliptic, đồng thời yêu cầu kích thước khóa rất lớn (như RSA-2048 bit) để bù đắp các lỗ hổng toán học tiềm ẩn.

Một sự khác biệt mang tính quyết định nằm ở khả năng quản lý và mở rộng hệ thống. Mật mã đối xứng gặp khó khăn lớn khi số lượng khóa tăng theo cấp số nhân (N(N-1)/2), khiến việc phân phối khóa an toàn trở thành bài toán nan giải. Trong khi đó, mật mã bất đối xứng giải quyết vấn đề này dễ dàng hơn nhiều khi số lượng khóa chỉ tăng tuyến tính (2N) và khóa công khai có thể được chia sẻ thoải mái mà không lo ngại rủi ro.

Xét trên khía cạnh an toàn thông tin, mặc dù cả hai đều đảm bảo tính bí mật cao, nhưng mật mã bất đối xứng vượt trội hơn hẳn về tính xác thực và khả năng chống chối bỏ. Nếu như mật mã đối xứng có tính xác thực yếu và người gửi có thể chối bỏ hành động của mình vì nhiều người cùng giữ khóa, thì mật mã bất đối xứng lại cho phép xác thực chính xác danh tính người gửi thông qua chữ ký số, khiến họ không thể chối cãi về mặt pháp lý.

Cuối cùng, mỗi loại hình đều đối mặt với những nguy cơ và ứng dụng riêng biệt. Mật mã đối xứng với các thuật toán tiêu biểu như AES, DES thường được dùng để mã hóa dữ liệu lớn như ổ cứng hay đường truyền VPN, nhưng lại gặp rủi ro lớn nhất là mất khóa. Ngược lại, mật mã bất đối xứng với RSA, ECC chủ yếu phục vụ cho việc trao đổi khóa phiên, chữ ký số và xác thực SSL, tuy nhiên lại phải đối mặt với nguy cơ tấn công Man-in-the-Middle và phụ thuộc vào sự chứng thực của các tổ chức CA.

1.2. Chữ ký số

Quy trình tạo & kiểm tra

Bước 1: Tạo Dấu vân tay cho dữ liệu (Hashing)

- Vấn đề: Các thuật toán mật mã bất đối xứng (như RSA) rất chậm và chỉ xử lý được dữ liệu có kích thước nhỏ. Việc dùng Private Key để mã hóa trực tiếp một file hợp đồng PDF nặng 10MB là không khả thi về mặt hiệu năng.

- Giải pháp: Hệ thống sử dụng hàm băm (như SHA-256) để tóm tắt văn bản đó thành một chuỗi ký tự cố định duy nhất (ví dụ: 256 bit). Chuỗi này gọi là Message Digest (Bản tóm lược) hay Dấu vân tay số .

- Đặc điểm: Chỉ cần văn bản gốc thay đổi một dấu chấm, giá trị băm sẽ thay đổi hoàn toàn ->Đảm bảo tính toàn vẹn.

Bước 2: Tạo chữ ký (Signing)

- Người gửi dùng Private Key (Khóa bí mật) của mình để mã hóa cái Dấu vân tay ở bước 1.

- Khối dữ liệu nhỏ đã được mã hóa này chính là Chữ ký số.

- Chữ ký này được đính kèm vào file gốc để gửi đi.

- *Lưu ý:* File gốc thường không bị mã hóa, nó vẫn ở dạng văn bản thường (Plaintext) để người nhận có thể đọc. Chữ ký số chỉ đi kèm để chứng thực file đó thôi.

Bước 3: Xác thực (Verifying)

- Người nhận tách file thành 2 phần: [Văn bản gốc] và [Chữ ký số].

- Luồng 1 (Kiểm tra sự toàn vẹn): Người nhận tự băm [Văn bản gốc] \rightarrow Ra giá trị H_2.

- Luồng 2 (Kiểm tra nguồn gốc): Người nhận dùng Public Key của người gửi để giải mã [Chữ ký số] -> Ra giá trị H_1.

- So sánh:

+ Nếu $H_1 = H_2$: Chắc chắn văn bản chưa bị sửa và đúng là do chủ nhân Private Key gửi.

+ Nếu H_1 / H_2: Hoặc văn bản đã bị sửa, hoặc người gửi là giả mạo. Văn bản bị coi là vô hiệu.

Chữ ký số giải quyết triệt để 3 bài toán lớn nhất trong giao dịch điện tử

- Tính xác thực (Authentication): Vì chỉ có đúng 1 người nắm giữ Private Key, nên nếu Public Key giải mã thành công, ta khẳng định được 100% danh tính người gửi (giả sử Private Key chưa bị lộ).

- Tính toàn vẹn (Integrity): Cơ chế hàm băm đảm bảo rằng nội dung không bị thay đổi dù chỉ 1 bit trong quá trình truyền tải. Nếu hacker chặn đường truyền và sửa số tiền trong hợp đồng từ 1 tỷ thành 10 tỷ, giá trị băm sẽ thay đổi và quy trình kiểm tra chữ ký sẽ thất bại ngay lập tức.

- Tính chống chối bỏ (Non-repudiation): Đây là tính năng quan trọng nhất về mặt pháp lý. Trong môi trường truyền thống, một người có thể chối: "Chữ ký này do ai đó giả mạo nét chữ của tôi". Nhưng với chữ ký số, về mặt toán học, không ai có thể tạo ra chữ ký đó nếu không có Private Key. Do đó, người ký không thể chối bỏ trách nhiệm pháp lý đối với nội dung mình đã ký.

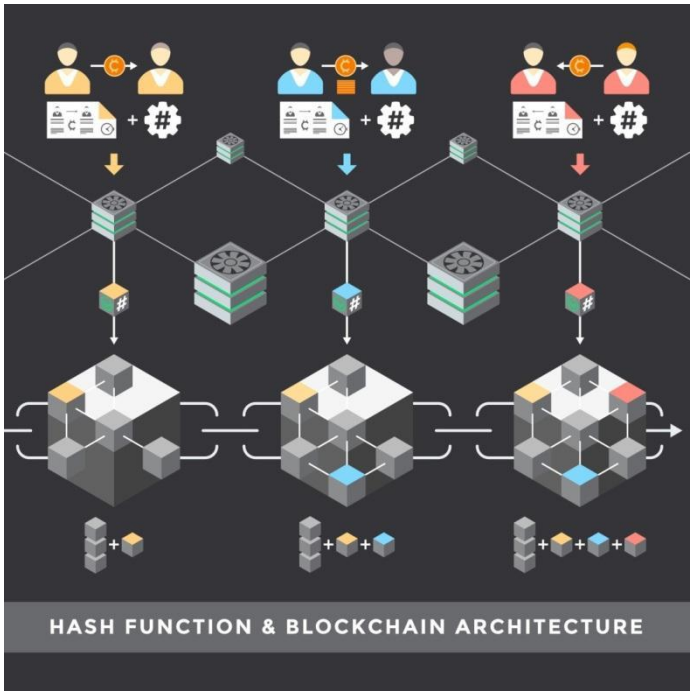
1.3. Hàm băm

Hàm băm có thể được ví như dấu vân tay kỹ thuật số của dữ liệu. Giống như vân tay con người giúp định danh duy nhất một cá nhân, giá trị băm (hash value) giúp định danh duy nhất một khối dữ liệu.

Về mặt toán học, hàm băm H lấy một đầu vào x (message) và trả về một chuỗi ký tự có độ dài cố định h (digest):

$H(x) = h$

Điều đặc biệt là x có thể là một ký tự, một bức ảnh, một file văn bản hay cả một bộ phim 4K, nhưng h sẽ luôn có độ dài cố định (ví dụ: 256 bit đối với SHA-256).



Ngoài 3 đặc điểm ta đã nêu trên thì sau đây là những tính chất quan trọng:

Tính một chiều (Pre-image Resistance)

Đây là tính chất quan trọng nhất để bảo mật mật khẩu. Hàm băm hoạt động giống như việc xay thịt. Bạn có thể dễ dàng biến con bò thành thịt xay, nhưng không thể nào ghép thịt xay trở lại thành con bò.

Ví dụ: Nếu bạn có giá trị băm 5e884898da28... (của từ "password"), không có công thức toán học nào cho phép bạn đảo ngược lại để tìm ra chữ "password" gốc. Kẻ tấn công chỉ có thể đoán (brute-force) chứ không thể giải ngược.

Hiệu ứng tuyết lở (Avalanche Effect) - Sự nhạy cảm tuyệt đối

Hàm băm được thiết kế để khuếch đại sự thay đổi. Dù thay đổi nhỏ nhất ở đầu vào cũng làm thay đổi khoảng 50% các bit ở đầu ra.

Ví dụ minh họa với SHA-256:

Đầu vào 1: Hello

Đầu ra 1:

185f8db32271fe25f561a6fc938b2e264306ec304eda518007d1764826381969

Đầu vào 2: hello (chỉ thay đổi chữ H hoa thành thường)

Đầu ra 2:

2cf24dba5fb0a30e26e83b2ac5b9e29e1b161e5c1fa7425e73043362938b9824

Kết quả: Hai chuỗi hoàn toàn khác nhau. Điều này ngăn cản kẻ tấn công tìm ra mối liên hệ giữa các đầu vào tương tự nhau.

Khả năng chống va chạm (Collision Resistance)

Theo lý thuyết nguyên lý chuồng bồ câu, vì đầu ra có độ dài cố định (hữu hạn) mà đầu vào là vô hạn, nên chắc chắn sẽ có sự trùng lặp (va chạm). Tuy nhiên, một hàm băm tốt phải làm cho việc tìm ra sự va chạm này trở nên bất khả thi về mặt tính toán.

Nếu hacker tìm được 2 file khác nhau có cùng mã hash, họ có thể thay thế file hợp lệ bằng file chứa mã độc mà hệ thống không phát hiện ra.

Tính xác định (Deterministic)

Cùng một đầu vào sẽ **luôn luôn** tạo ra cùng một đầu ra. Nếu bạn băm file Tai_lieu.pdf hôm nay và 10 năm sau băm lại file đó, kết quả phải y hệt nhau. Đây là cơ sở để kiểm tra tính toàn vẹn dữ liệu.

Một số thuật toán phổ biến

MD5 (Message Digest Algorithm 5) MD5 từng là thuật toán băm phổ biến nhất thế giới trong thập niên 90 và đầu những năm 2000. Thuật toán này tạo ra một chuỗi giá trị băm có độ dài 128-bit (thường được biểu diễn bằng 32 ký tự thập lục phân). Ưu điểm lớn nhất của MD5 là tốc độ xử lý cực nhanh và tốn ít tài nguyên hệ thống. Tuy nhiên, chính vì cấu trúc quá đơn giản so với năng lực tính toán hiện đại, MD5 đã bị phát hiện nhiều lỗ hổng nghiêm trọng liên quan đến khả năng chống va chạm. Ngày nay, các chuyên gia bảo mật khuyến cáo tuyệt đối không sử dụng MD5 cho các mục đích bảo mật như lưu trữ mật khẩu hay chữ ký số. Mặc dù vậy, do tốc độ nhanh, nó vẫn được sử dụng rộng rãi trong các tác vụ phi bảo mật, điển hình là kiểm tra tính toàn vẹn của tập tin (checksum) để đảm bảo file tải về không bị lỗi đường truyền.

SHA-1 (Secure Hash Algorithm 1) Được thiết kế bởi Cơ quan An ninh Quốc gia Hoa Kỳ (NSA) để khắc phục các hạn chế của MD5, SHA-1 tạo ra bản băm dài hơn là 160-bit. Trong một thời gian dài, SHA-1 là tiêu chuẩn mặc định cho hầu hết các chứng chỉ bảo mật trên internet (SSL/TLS). Tuy nhiên, số phận của SHA-1 cũng tương tự như MD5 khi năng lực tính toán của máy tính tăng lên theo định luật Moore. Vào năm 2017, Google đã công bố cuộc tấn công SHAttered, chứng minh rằng họ có thể tạo ra hai tệp PDF khác nhau nhưng có cùng một mã băm SHA-1. Kể từ đó, các trình duyệt web lớn như Chrome, Edge và Firefox đã chính thức loại bỏ hỗ trợ SHA-1. Hiện tại, thuật toán này chỉ còn tồn tại trong các hệ thống di sản (legacy systems) cũ kỹ và được coi là không còn an toàn.

SHA-2 (Secure Hash Algorithm 2) Đây là họ thuật toán đang đóng vai trò là xương sống của bảo mật internet hiện đại. SHA-2 không phải là một thuật toán đơn lẻ mà là một tập hợp bao gồm nhiều phiên bản với độ dài đầu ra khác nhau, phổ biến nhất là SHA-256 và SHA-512. SHA-2 khắc phục hoàn toàn các điểm yếu của SHA-1 và cho đến nay vẫn chưa có phương pháp tấn công thực tế nào có thể phá vỡ được nó. SHA-256 hiện diện ở khắp mọi nơi: từ giao thức bảo mật HTTPS (ổ khóa xanh trên trình duyệt), chữ ký số trong giao dịch ngân hàng, cho đến cốt lõi của công nghệ Blockchain (như Bitcoin). Khi nói đến một lựa chọn cân bằng giữa hiệu suất và độ an toàn cho các ứng dụng ngày nay, SHA-256 là lựa chọn tiêu chuẩn.

Các thuật toán băm chuyên dụng cho mật khẩu (Bcrypt, Argon2, PBKDF2) Một điểm quan trọng cần phân biệt là các thuật toán như MD5, SHA-1 hay SHA-2 được

thiết kế để chạy càng nhanh càng tốt. Điều này rất tốt cho việc xử lý dữ liệu lớn nhưng lại là con dao hai lưỡi khi dùng để lưu trữ mật khẩu, vì hacker có thể dùng phần cứng mạnh để đoán thử (brute-force) hàng tỷ mật khẩu mỗi giây. Do đó, trong lập trình ứng dụng hiện đại, người ta sử dụng các thuật toán băm được thiết kế cố tình để chạy chậm và tốn tài nguyên như Bcrypt, Argon2 hay PBKDF2. Các thuật toán này buộc hệ thống phải tốn một khoảng thời gian nhất định (ví dụ: 0.5 giây) và một lượng RAM nhất định để băm một mật khẩu, khiến việc tấn công dò mật khẩu trở nên bất khả thi về mặt thời gian đối với hacker.

CHƯƠNG II: CƠ SỞ HẠ TẦNG KHÓA CÔNG KHAI

2.1. Khái niệm cơ bản về hệ thống PKI

ĐỊnh nghĩa

Cơ sở hạ tầng khóa công khai (Public Key Infrastructure - PKI) không đơn thuần là một phần mềm hay một thiết bị phần cứng, mà là một tập hợp tổng thể bao gồm phần cứng, phần mềm, con người, chính sách và các thủ tục cần thiết để tạo, quản lý, lưu trữ, phân phối và thu hồi các chứng thư số (digital certificates) dựa trên mã hóa khóa công khai.

Mục tiêu cốt lõi của PKI là thiết lập và duy trì một môi trường mạng tin cậy, nơi mà các thực thể (người dùng, máy chủ, thiết bị IoT) có thể xác thực danh tính của nhau và trao đổi thông tin một cách bảo mật mà không cần quen biết hay tin tưởng nhau từ trước. PKI giải quyết vấn đề lớn nhất của mã hóa bất đối xứng: Làm sao để biết Khóa công khai (Public Key) này thực sự thuộc về người mà nó tuyên bố? Thông qua cơ chế của bên thứ ba tin cậy (Trusted Third Party), PKI gắn kết một khóa công khai với một định danh thực thể (Identity) thông qua Chứng thư số.

Thành phần kiến trúc PKI

Một hệ thống PKI tiêu chuẩn tuân theo các khuyến nghị của ITU-T X.509 bao gồm các thành phần chính sau:

Tổ chức cấp phát chứng thư số (Certificate Authority - CA):

Đây được xem là trái tim của hệ thống PKI. CA là một thực thể uy tín chịu trách nhiệm phát hành và quản lý vòng đời của chứng thư số.

Chức năng: CA tiếp nhận yêu cầu, xử lý và ký số lên chứng thư số của người dùng bằng khóa bí mật (Private Key) của chính CA.

Mô hình phân cấp: Thông thường, PKI hoạt động theo mô hình hình cây. *Root CA (CA gốc):* Là đỉnh của niềm tin, tự ký chứng thư số cho chính mình. *Sub-CA/Intermediate CA (CA trung gian):* Được Root CA cấp phép để phát hành chứng thư cho người dùng cuối, giúp giảm tải rủi ro cho Root CA.

Cơ quan đăng ký (Registration Authority - RA):

RA đóng vai trò là cánh tay nối dài hoặc giao diện giữa người dùng và CA. Chức năng: RA chịu trách nhiệm xác minh danh tính thực của người yêu cầu cấp chứng thư số (ví dụ: kiểm tra CMND/CCCD, giấy phép kinh doanh của doanh nghiệp).

RA không ký phát hành chứng thư số mà chỉ phê duyệt yêu cầu và chuyển tiếp đến CA để xử lý. Trong một số hệ thống hiện đại, chức năng của RA có thể được tích hợp vào CA nhưng về mặt logic, đây là hai quy trình riêng biệt.

Kho lưu trữ (Repository/Directory Service):

Đây là nơi lưu trữ và công bố các chứng thư số và danh sách thu hồi chứng thư (CRL).

Giao thức: Thường sử dụng giao thức LDAP (Lightweight Directory Access Protocol) hoặc HTTP để người dùng có thể dễ dàng truy vấn và tải về khóa công khai của đối tác.

Cơ quan xác thực (Validation Authority - VA):

Thành phần này cung cấp dịch vụ kiểm tra trạng thái của chứng thư số trong thời gian thực. Thay vì phải tải toàn bộ danh sách thu hồi (CRL) về máy, người dùng có thể gửi truy vấn đến VA thông qua giao thức OCSP (Online Certificate Status Protocol) để biết chứng thư số còn hiệu lực hay không.

Chứng thư số và chuẩn X.509

Chứng thư số là một tệp dữ liệu điện tử, hoạt động như một hộ chiếu điện tử để chứng minh quyền sở hữu khóa công khai. Định dạng phổ biến nhất hiện nay là chuẩn X.509 v3. Cấu trúc của một chứng thư số bao gồm các trường thông tin quan trọng:

Version: Phiên bản của chuẩn X.509 (thường là v3).

Serial Number: Số sê-ri duy nhất do CA cấp phát cho chứng thư số. **Signature**

Algorithm: Thuật toán băm và ký số được CA sử dụng (ví dụ: sha256WithRSAEncryption).

Issuer: Tên định danh của CA phát hành chứng thư.

Validity: Khoảng thời gian hiệu lực (từ ngày... đến ngày...).

Subject: Tên định danh của chủ sở hữu chứng thư (thường theo chuẩn X.500 DN như CN=NguyenVanA, O=CongTyABC, C=VN).

Subject Public Key Info: Chứa khóa công khai của người dùng và thuật toán khóa (RSA, ECC...).

Extensions: Các thông tin mở rộng (ví dụ: mục đích sử dụng khóa - Key Usage, chính sách cấp phát...).

Quy trình quản lý vòng đời chứng thư số

Một hệ thống PKI hoàn chỉnh phải quản lý chặt chẽ toàn bộ vòng đời chứng thư:

1. Đăng ký (Registration): Người dùng gửi yêu cầu và bằng chứng xác thực danh tính tới RA.

2. Khởi tạo (Key Generation): Cặp khóa (Private/Public) được tạo ra. Khóa bí mật có thể được tạo trên thiết bị của người dùng (USB Token/HSM) hoặc tạo tập trung tại CA (đối với Smart Cloud Signing).

3. Phát hành (Issuance): CA ký số lên thông tin khóa công khai và danh tính người dùng, tạo ra chứng thư số.

4. Phân phối (Distribution): Chứng thư số được gửi cho người dùng và công bố trên kho lưu trữ.

5. Sử dụng (Usage): Người dùng dùng khóa bí mật để ký/giải mã; đối tác dùng chứng thư số để xác thực/mã hóa.

6. Thu hồi (Revocation): Nếu khóa bí mật bị lộ hoặc thông tin người dùng thay đổi, CA sẽ thu hồi chứng thư trước thời hạn và đưa vào danh sách đen (CRL - Certificate Revocation List).

7. Hết hạn/Gia hạn (Expiration/Renewal): Khi hết thời gian hiệu lực, chứng thư số cần được gia hạn hoặc cấp mới.

2.2. Thực trạng PKI tại Việt Nam

Cơ sở pháp lý và môi trường chính sách

Một hệ thống PKI hoàn chỉnh không chỉ dừng lại ở việc cấp phát mà phải bao quát chặt chẽ toàn bộ vòng đời của chứng thư số, bắt đầu từ giai đoạn Đăng ký. Tại bước này, người dùng gửi yêu cầu kèm theo các bằng chứng xác thực danh tính tới Cơ quan đăng ký (RA) để thẩm định. Tiếp nối là quá trình Khởi tạo, nơi cặp khóa công khai và bí mật được sinh ra; tùy thuộc vào mô hình bảo mật, khóa bí mật có thể được tạo và lưu trữ cục bộ trên thiết bị phần cứng của người dùng (như USB Token, HSM) hoặc được tạo tập trung tại CA đối với các giải pháp Smart Cloud Signing hiện đại.

Sau khi các bước chuẩn bị hoàn tất, CA sẽ tiến hành Phát hành chứng thư số bằng cách ký số lên thông tin định danh và khóa công khai của người dùng, trước khi Phân phối nó đến tay chủ sở hữu cũng như công bố rộng rãi trên các kho lưu trữ. Trong giai đoạn Sử dụng thường nhật, người dùng sẽ vận dụng khóa bí mật để thực hiện ký số hoặc

giải mã, trong khi các đối tác tin cậy sẽ sử dụng chứng thư số để xác thực danh tính hoặc mã hóa dữ liệu gửi đi.

Tuy nhiên, để đảm bảo an toàn tuyệt đối, hệ thống luôn duy trì cơ chế Thu hồi nghiêm ngặt. Trong trường hợp khóa bí mật bị lộ hoặc thông tin người dùng có sự thay đổi, CA sẽ ngay lập tức hủy bỏ hiệu lực của chứng thư trước thời hạn và cập nhật vào Danh sách thu hồi (CRL). Cuối cùng, khi chứng thư đi đến giai đoạn Hết hạn, người dùng bắt buộc phải thực hiện thủ tục gia hạn hoặc cấp mới để đảm bảo tính liên tục và pháp lý cho các giao dịch điện tử.

Kiến trúc PKI quốc gia Việt Nam

Hệ thống PKI tại Việt Nam được chia làm hai nhánh chính, hoạt động độc lập nhưng tuân thủ các tiêu chuẩn chung:

Hệ thống Chứng thực chữ ký số quốc gia (Root CA): Được quản lý bởi Trung tâm Chứng thực điện tử quốc gia (NEAC) thuộc Bộ Thông tin và Truyền thông.

- Đây là gốc tín nhiệm (Root of Trust) duy nhất cho khối dịch vụ công cộng.
- NEAC cấp chứng thư số cho các CA công cộng (như VNPT-CA, Viettel-CA...) và giám sát hoạt động của các đơn vị này.
- NEAC cũng duy trì hệ thống kỹ thuật để liên thông, công nhận chéo chữ ký số với các quốc gia khác.

Hệ thống Chứng thực chữ ký số chuyên dùng Chính phủ (VGCA): Được quản lý bởi Ban Cơ yếu Chính phủ.

- Hệ thống này phục vụ riêng cho các cơ quan Đảng, Nhà nước và hệ thống chính trị.
- Đặc điểm của hệ thống này là yêu cầu bảo mật cao hơn, sử dụng các tiêu chuẩn mã hóa riêng hoặc các thiết bị bảo mật chuyên dụng do ngành Cơ yếu quy định nhằm đảm bảo bí mật nhà nước.

Thị trường dịch vụ chứng thực chữ ký số công cộng

Thị trường CA tại Việt Nam phát triển rất sôi động với sự cạnh tranh gay gắt. Tính đến năm 2024-2025, đã có hơn 20 nhà cung cấp dịch vụ chứng thực chữ ký số công cộng được cấp phép hoạt động.

- Các đơn vị dẫn đầu: Thị phần lớn chủ yếu thuộc về các tập đoàn công nghệ và viễn thông lớn như VNPT-CA, Viettel-CA, BKAV-CA, FPT-CA, MISA-CA...

- Sự dịch chuyển công nghệ:

Giai đoạn trước 2020: Chủ yếu sử dụng USB Token. Đây là thiết bị phần cứng chứa khóa bí mật, người dùng phải cắm vào máy tính mới ký được. Nhược điểm là bất tiện, dễ thất lạc và khó dùng trên điện thoại di động.

Giai đoạn hiện nay: Xu hướng chuyển dịch mạnh mẽ sang Ký số từ xa (Remote Signing) và Smart CA. Với công nghệ này, khóa bí mật được lưu trữ tập trung trên HSM (Hardware Security Module) của nhà cung cấp dịch vụ. Người dùng có thể ký số mọi lúc, mọi nơi trên thiết bị di động (smartphone, tablet) thông qua cơ chế xác thực đa yếu tố (MFA) mà không cần USB Token. Điều này đã thúc đẩy mạnh mẽ việc phổ cập chữ ký số cá nhân.

2.3. Định nghĩa về cơ sở hạ tầng khóa công khai

Theo tiêu chuẩn quốc tế

Mặc dù có nhiều cách diễn giải khác nhau, nhưng định nghĩa chính xác và đầy đủ nhất về PKI được chấp nhận rộng rãi trong giới nghiên cứu bảo mật dựa trên khuyến nghị của tổ chức IETF (Internet Engineering Task Force) trong tài liệu RFC 5280.

Theo đó, Cơ sở hạ tầng khóa công khai (PKI) được định nghĩa là một tập hợp bao gồm phần cứng (hardware), phần mềm (software), con người (people), chính sách (policies) và các quy trình thủ tục (procedures) cần thiết để tạo lập, quản lý, lưu trữ, phân phối và thu hồi các chứng thư số dựa trên mã hóa khóa công khai.

PKI không chỉ là một giải pháp công nghệ đơn lẻ, mà là một hạ tầng niềm tin (Trust Infrastructure). Nó cung cấp nền tảng để các ứng dụng khác (như e-banking, e-government, thương mại điện tử) có thể vận hành một cách an toàn.

Thành phần cốt lõi

Một hệ thống PKI hoàn chỉnh và vững mạnh được cấu thành từ sự phối hợp chặt chẽ của năm yếu tố then chốt. Đầu tiên là nền tảng Phần cứng (Hardware), đóng vai trò như lớp khiên vật lý bảo vệ an toàn cho hệ thống, bao gồm các máy chủ bảo mật, thiết bị lưu trữ khóa chuyên dụng cao cấp như HSM (Hardware Security Module) dành cho nhà cung cấp CA, và các thiết bị lưu trữ cá nhân như USB Token hoặc Smartcard dành cho người dùng cuối. Vận hành trên nền tảng đó là thành phần Phần mềm (Software), bao gồm hệ điều hành, các giải pháp phần mềm chuyên dụng để quản lý CA (như

EJBCA hay Microsoft AD CS), hệ thống đăng ký (RA) cùng các trình điều khiển (middleware) giúp thiết bị người dùng giao tiếp trơn tru với hệ thống.

Tuy nhiên, yếu tố mang tính quyết định nhất lại là Con người bao gồm đội ngũ quản trị viên an ninh chịu trách nhiệm vận hành hệ thống, nhân viên thẩm định danh tính tại RA và cộng đồng người dùng cuối. Để quản lý sự tương tác giữa các yếu tố này, hệ thống cần thiết lập bộ Chính sách (Policies) nhằm quy định rõ ràng luật chơi, điển hình là Chính sách chứng thư số (CP) giúp xác định phạm vi sử dụng, độ mạnh của khóa và trách nhiệm pháp lý liên quan. Cuối cùng, các chính sách này được hiện thực hóa thông qua các Quy trình (Procedures) cụ thể, từ các bước xác minh danh tính nghiêm ngặt khi cấp phát chứng thư cho đến các kịch bản ứng phó khẩn cấp trong trường hợp lộ khóa Root CA.

2.4. Chức năng các thành phần chính của PKI

Dựa trên kiến trúc tiêu chuẩn X.509, chức năng của các thành phần trong PKI được phân định rõ ràng và chuyên biệt hóa như sau:

Chức năng của Tổ chức cấp phát chứng thư số (Certification Authority - CA)

CA là thực thể tin cậy tối cao trong hệ thống. Chức năng của CA không chỉ dừng lại ở việc cấp chứng thư mà bao gồm các nhiệm vụ kỹ thuật phức tạp:

- Phát hành chứng thư số (Issuance): CA tiếp nhận yêu cầu đã được xác thực từ RA, sử dụng khóa bí mật của CA để ký số lên thông tin người dùng, tạo ra chứng thư số X.509 hợp lệ.

- Quản lý vòng đời chứng thư (Lifecycle Management): Theo dõi trạng thái của mọi chứng thư số từ khi sinh ra, gia hạn (renew), tạm ngưng (suspend) cho đến khi hết hạn hoặc bị thu hồi.

- Công bố danh sách thu hồi (CRL Publishing): Định kỳ phát hành danh sách các chứng thư số không còn giá trị (do mất khóa, nhân viên nghỉ việc...). Bản danh sách này (CRL) cũng phải được ký số bởi CA để đảm bảo không bị giả mạo.

- Lưu trữ khóa (Key Archival/Escrow): (Tùy chọn) Trong một số trường hợp (thường là khóa dùng để mã hóa dữ liệu, không phải khóa dùng để ký), CA có chức năng sao lưu khóa bí mật của người dùng để phục hồi dữ liệu khi người dùng làm mất khóa.

Lưu ý về phân cấp chức năng CA:

- *Root CA:* Chức năng duy nhất là cấp chứng thư và ủy quyền cho các CA trung gian (Sub-CA). Root CA thường được tắt nguồn (offline) và cất giữ trong két sắt an toàn để tránh bị tấn công mạng.

- *Issuing CA (Sub-CA):* Là CA hoạt động online, trực tiếp cấp chứng thư cho người dùng cuối.

Chức năng của Cơ quan đăng ký (Registration Authority - RA)

RA đóng vai trò giống như là người gác cổng (Gatekeeper). Chức năng chính là giảm tải cho CA và đảm bảo tính chính xác của thông tin:

- Xác thực danh tính (Identity Proofing): Kiểm tra giấy tờ tùy thân (CMND/CCCD/Passport) hoặc giấy phép kinh doanh của tổ chức. Đối với mức độ bảo mật cao, RA yêu cầu sự hiện diện trực tiếp (Face-to-face) của người đăng ký.

- Xác minh quyền sở hữu khóa (Proof of Possession - POP): Đảm bảo người yêu cầu chứng thư thực sự đang nắm giữ khóa bí mật tương ứng với khóa công khai mà họ gửi lên.

- Khởi tạo yêu cầu thu hồi: Khi người dùng báo mất thiết bị token, RA là nơi tiếp nhận thông báo và chuyển yêu cầu thu hồi lên CA.

Chức năng của Kho lưu trữ và Phân phối (Repository / Directory Service)

Thành phần này đóng vai trò là cuốn danh bạ điện tử công cộng.

- Lưu trữ tập trung: Nơi chứa tất cả các chứng thư số đang hoạt động và các danh sách thu hồi (CRL).

- Cung cấp khả năng truy vấn: Cho phép các ứng dụng của bên thứ ba tìm kiếm và tải về khóa công khai của người dùng khác để thực hiện mã hóa dữ liệu gửi đi. Giao thức thường dùng là LDAP (Lightweight Directory Access Protocol).

Chức năng của Cơ quan xác thực trạng thái (Validation Authority - VA)

Trong các hệ thống hiện đại, VA giải quyết vấn đề độ trễ của danh sách CRL.

- Phản hồi trực tuyến (OCSP Responder): Thay vì người dùng phải tải một file CRL dung lượng lớn về máy, VA cung cấp dịch vụ trả lời trạng thái ngay lập tức.

- Quy trình: Người dùng hỏi "Chứng thư số serial 12345 còn tốt không?", VA trả lời Tốt (Good), Đã thu hồi (Revoked) hoặc Không biết (Unknown) trong thời gian thực.

Chức năng của Thực thể cuối (End Entity - EE)

Thường bị bỏ qua trong các định nghĩa hẹp, nhưng EE là một thành phần chức năng không thể thiếu.

- Sinh khóa (Key Generation): Tạo ra cặp khóa Công khai/Bí mật (trừ khi khóa được tạo tập trung tại CA).

- Bảo vệ khóa bí mật: Chịu trách nhiệm giữ an toàn tuyệt đối cho khóa bí mật (trong Smartcard, USB Token hoặc HSM).

- Thực hiện thuật toán: Sử dụng phần mềm client để thực hiện các phép toán ký số hoặc giải mã dữ liệu.

2.5. Cách thức hoạt động của PKI

Cơ sở hạ tầng khóa công khai hoạt động dựa trên sự kết hợp giữa Mật mã học bất đối xứng (Asymmetric Cryptography) và Mô hình tin cậy phân cấp (Hierarchical Trust Model). Để hệ thống vận hành trơn tru, PKI thiết lập một mối quan hệ kiềng ba chân giữa: Người sở hữu chứng thư (Subscriber), Tổ chức cấp phát (CA), và Bên tin cậy (Relying Party).

2.5.1. Cơ chế cặp khóa (Key Pair Mechanism)

Khác với mật mã đối xứng (chỉ dùng 1 khóa), PKI hoạt động dựa trên cặp khóa toán học có quan hệ mật thiết nhưng không thể suy diễn ra nhau:

- Khóa công khai (Public Key - K_{pub}): Được công bố rộng rãi cho bất kỳ ai.

- Khóa bí mật (Private Key - K_{prv}): Được giữ bí mật tuyệt đối bởi chủ sở hữu.

Quy tắc hoạt động cơ bản được mô tả bằng toán học như sau:

Nếu M là thông điệp dữ liệu, E là hàm mã hóa và D là hàm giải mã:

1. Cơ chế bảo mật (Mã hóa dữ liệu):

Trong kịch bản người gửi muốn chuyển một thông điệp bí mật dành riêng cho người nhận A, quy trình mã hóa sẽ đóng vai trò như một chiếc két sắt số. Cụ thể, người gửi sẽ sử dụng chính khóa công khai của A (K_{pubA}) để mã hóa thông điệp gốc M thành bản mã C, được biểu diễn qua công thức $C = E(M, K_{pubA})$.

Do đặc tính toán học của hệ thống bất đối xứng, bản mã này không thể bị giải ngược bởi chính chiếc khóa đã khóa nó. Chỉ duy nhất người nhận A – người nắm giữ khóa bí mật tương ứng (K_{prv_A}) – mới có khả năng thực hiện phép giải mã để khôi phục lại nội dung gốc thông qua công thức $M = D(C, K_{prvA})$. Nguyên lý này đảm bảo rằng dù

tin tặc có chặn được đường truyền, chúng cũng không thể đọc được nội dung, từ đó bảo vệ tuyệt đối tính bí mật của dữ liệu.

2. Cơ chế xác thực (Chữ ký số):

Khi người dùng A muốn chứng minh văn bản M thực sự do mình soạn thảo và đảm bảo rằng nội dung chưa từng bị chỉnh sửa, quy trình sẽ diễn ra theo hướng ngược lại với mã hóa bí mật. Đầu tiên, A sử dụng khóa bí mật của riêng mình (ký hiệu là K_{prv}) để thực hiện việc ký số. Về mặt kỹ thuật, quá trình này thực chất là mã hóa giá trị băm của văn bản M theo công thức: $S = E(Hash(M), K_{prv})$.

Sau đó, bất kỳ ai muốn kiểm tra tính xác thực đều có thể sử dụng khóa công khai của A (ký hiệu là K_{pub}) để giải mã chữ ký S. Nếu kết quả giải mã khớp hoàn toàn với giá trị băm của văn bản gốc (tức là $D(S, K_{pub}) = Hash(M)$), thì chữ ký được coi là hợp lệ. Cơ chế này không chỉ đảm bảo tính toàn vẹn (Integrity) của dữ liệu mà còn đảm bảo tính chống chối bỏ (Non-repudiation), bởi về mặt toán học, không ai khác ngoài A có thể tạo ra chữ ký đó.

2.5.2. Chuỗi tin cậy (Chain of Trust)

Đây được xem như là linh hồn của cách thức hoạt động PKI. Làm sao trình duyệt web hoặc máy chủ biết một chứng thư số là thật? Nó dựa vào quy trình kiểm tra ngược dòng:

- End-Entity Certificate: Khi người dùng truy cập một trang web (ví dụ: Google), server gửi về chứng thư số của nó.

- Intermediate CA: Máy tính kiểm tra xem ai đã ký chứng thư của Google. Nó thấy "Google Internet Authority".

- Root CA: Máy tính tiếp tục kiểm tra ai đã ký "Google Internet Authority". Nó thấy "GlobalSign Root CA".

- Trust Anchor: Hệ điều hành (Windows, macOS) hoặc Trình duyệt đã được cài sẵn danh sách các Root CA uy tín. Nếu "GlobalSign Root CA" nằm trong danh sách này \rightarrow Chuỗi tin cậy hợp lệ.

Nếu chuỗi bị đứt gãy ở bất kỳ mắt xích nào (ví dụ: Intermediate CA không được Root CA xác nhận), toàn bộ quá trình xác thực sẽ thất bại và cảnh báo bảo mật sẽ xuất hiện.

2.6. Các tiến trình trong PKI

Để quản lý vòng đời của một chứng thư số, PKI vận hành thông qua các quy trình chuẩn hóa nghiêm ngặt. Dưới đây là các tiến trình kỹ thuật chính diễn ra trong thực tế.

2.6.1. Tiến trình Đăng ký và Cấp phát (Enrollment Process)

Đây là quy trình khởi tạo danh tính số cho người dùng.

- Tạo cặp khóa: Cặp khóa (K_{pub}, K_{prv}) được sinh ra. Để an toàn nhất, việc này nên thực hiện trên thiết bị của người dùng (client-side) để K_{prv} không bao giờ rời khỏi máy họ.

- Tạo CSR (Certificate Signing Request): Đây là bước kỹ thuật quan trọng nhất. Người dùng tạo một file CSR chứa:

+ Khóa công khai (K_{pub}).

+ Thông tin định danh (Tên, Tổ chức, Quốc gia...).

+ Chữ ký số của chính người dùng (để chứng minh họ đang giữ K_{prv} tương ứng).

- Gửi yêu cầu: CSR được gửi tới RA (Registration Authority).

- Xác thực: RA kiểm tra thông tin thực tế (giấy tờ pháp lý) so khớp với thông tin trong CSR.

- Ký phát hành: Nếu hợp lệ, RA chuyển yêu cầu sang CA. CA dùng khóa bí mật của mình để ký lên CSR, tạo thành Chứng thư số (Certificate).

- Cài đặt: Chứng thư số được gửi lại cho người dùng để cài vào trình duyệt, máy chủ hoặc thiết bị token.

2.6.2. Tiến trình Xác thực Chứng thư (Certificate Validation Process)

Mỗi khi một giao dịch diễn ra (ví dụ: xác thực trang web HTTPS), bên tin cậy (Relying Party) phải thực hiện quy trình kiểm tra đa bước:

- Kiểm tra cú pháp: Đảm bảo chứng thư tuân thủ chuẩn X.509.

- Kiểm tra thời hạn: So sánh thời gian hiện tại với trường NotBefore và NotAfter trong chứng thư.

- Kiểm tra chữ ký: Dùng khóa công khai của CA để xác minh chữ ký trên chứng thư người dùng có bị giả mạo không.

- Kiểm tra trạng thái thu hồi (Revocation Checking): Đây là bước tốn tài nguyên nhất. Hệ thống phải truy vấn xem chứng thư này có bị CA hủy bỏ trước hạn hay không

thông qua hai giao thức: CRL (Certificate Revocation List): Tải danh sách đen về máy. OCSP (Online Certificate Status Protocol): Hỏi trực tiếp máy chủ của CA.

2.6.3. Tiến trình Thu hồi (Revocation Process)

Trong thực tế vận hành, không phải chứng thư số nào cũng duy trì hiệu lực đến ngày hết hạn định sẵn. Việc thu hồi chứng thư trước thời hạn là yêu cầu bắt buộc trong các tình huống rủi ro an ninh hoặc thay đổi về mặt hành chính, điển hình như khi khóa bí mật bị lộ hoặc nghi ngờ bị xâm nhập, thông tin định danh trong chứng thư có sự thay đổi (ví dụ nhân viên đổi tên, doanh nghiệp thay đổi địa chỉ), hoặc khi chủ sở hữu ngừng hoạt động hoàn toàn.

Quy trình xử lý sự cố này được kích hoạt ngay khi chủ sở hữu hoặc quản trị viên hệ thống gửi yêu cầu thu hồi chính thức tới tổ chức cấp phát (CA). Sau khi tiếp nhận và xác thực tính hợp lệ của yêu cầu, CA sẽ tiến hành cập nhật số serial định danh của chứng thư đó vào cơ sở dữ liệu thu hồi. Để hoàn tất quy trình và cảnh báo cho toàn bộ hệ thống mạng, CA sẽ phát hành một bản Danh sách thu hồi chứng thư (CRL) mới hoặc cập nhật trạng thái thời gian thực lên hệ thống OCSP Responder, qua đó công bố rộng rãi rằng chứng thư nói trên không còn độ tin cậy và cần bị từ chối trong mọi giao dịch xác thực.

2.6.4. Tiến trình Gia hạn và Phục hồi (Renewal & Recovery)

Khi chứng thư số đi dần đến cuối chu kỳ sống, quy trình Gia hạn (Renewal) trở nên cấp thiết để duy trì tính liên tục của hệ thống. Tại thời điểm này, người dùng đứng trước hai lựa chọn kỹ thuật: hoặc gia hạn dựa trên cặp khóa hiện tại (chỉ cập nhật thời gian hiệu lực), hoặc thực hiện tái tạo khóa (Rekey) – tức sinh ra cặp khóa hoàn toàn mới để cấp chứng thư mới. Trong đó, phương pháp Rekey luôn được các chuyên gia bảo mật khuyến nghị ưu tiên sử dụng nhằm giảm thiểu rủi ro thám mã theo thời gian và tăng cường độ an toàn cho chu kỳ mới.

Song song với đó, hệ thống PKI cũng cung cấp cơ chế Phục hồi khóa (Key Recovery), tuy nhiên tính năng này bị giới hạn nghiêm ngặt bởi mục đích sử dụng. Việc phục hồi – thường thông qua cơ chế lưu ký (Key Escrow) tại CA – chỉ được phép áp dụng đối với khóa mã hóa (Encryption Key) nhằm mục đích cứu dữ liệu khi người dùng đánh mất khóa giải mã. Ngược lại, một nguyên tắc bất di bất dịch trong an toàn thông tin là tuyệt đối không được phép sao lưu hay phục hồi khóa ký số (Signing Key). Lý do cốt lõi nằm ở chỗ, nếu bất kỳ bên thứ ba nào (kể cả CA) nắm giữ bản sao của khóa ký, tính chất chống chối bỏ sẽ bị phá vỡ hoàn toàn, khiến chữ ký số mất đi giá trị pháp lý độc nhất của nó.

CHƯƠNG III: ỨNG DỤNG CỦA PKI

Ứng dụng của PKI vào S/MIME

Phần thực nghiệm Ứng dụng PKI trong bảo mật thư điện tử S/MIME

Chuẩn bị

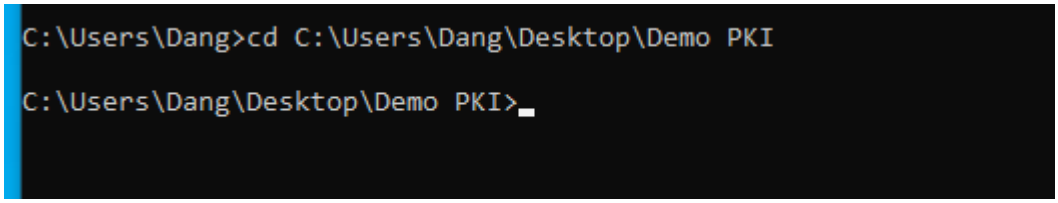
- Máy thực nghiệm: Đã cài OpenSSL và Mozilla Thunderbird.
- Email gửi (Sender): nguyenlehaidang010805@gmail.com (Cần cài chứng chỉ số).
- Email nhận (Receiver): nguyenlehaidang7@gmail.com (Dùng để kiểm tra).

Giai đoạn 1: Tạo cặp khóa và Chứng chỉ cho Email (Trên máy ảo)

Do S/MIME yêu cầu chứng chỉ phải gắn với địa chỉ email cụ thể, chúng ta cần tạo chứng chỉ mới cho email người gửi.

Bước 1: Mở CMD và vào thư mục DemoPKI và Tạo file cấu hình openssl.cnf

cd C:\Users\Dang \Desktop\DemoPKI



Hình 3.1: Cấu hình thư mục làm việc và file openssl.cnf trên Command Prompt .

- Mở Notepad (không cần quyền Admin cũng được vì đây là User Desktop).
- Copy và dán nội dung dưới đây vào:

```
[ ca ]
default_ca = CA_default

[ CA_default ]
dir             = .
certs           = $dir/certs
crl_dir         = $dir/crl
new_certs_dir   = $dir/newcerts
database        = $dir/index.txt
```

```
serial           = $dir/serial
private_key      = ./rootCA.key
certificate      = ./rootCA.crt
default_days     = 365
default_md       = sha256
policy           = policy_loose
copy_extensions  = copy
email_in_dn      = no

[ policy_loose ]
countryName            = optional
stateOrProvinceName    = optional
localityName           = optional
organizationName       = optional
organizationalUnitName = optional
commonName             = supplied
emailAddress           = optional

[ req ]
default_bits        = 2048
distinguished_name  = req_distinguished_name
string_mask         = utf8only
x509_extensions     = smime_cert

[ req_distinguished_name ]
commonName          = Common Name
emailAddress        = Email Address
```

```
[ v3_ca ]
subjectKeyIdentifier = hash
authorityKeyIdentifier = keyid:always,issuer
basicConstraints = critical, CA:true
keyUsage = critical, digitalSignature, cRLSign, keyCertSign

[ smime_cert ]
basicConstraints = CA:FALSE
nsCertType = client, email
nsComment = "OpenSSL Generated Certificate"
subjectKeyIdentifier = hash
authorityKeyIdentifier = keyid,issuer
keyUsage = critical, nonRepudiation, digitalSignature, keyEncipherment
extendedKeyUsage = clientAuth, emailProtection
subjectAltName = email:copy
```

Bước 2: Tạo Private Key cho người gửi

openssl genrsa -out sender.key 2048

```
C:\Users\Dang\Desktop\Demo PKI>openssl genrsa -out sender.key 2048
```

Hình 3.2: Câu lệnh tạo khóa bí mật (Private Key) cho người gửi .

Bước 3: Tạo yêu cầu chứng chỉ (CSR) chứa Email *Lưu ý: Ở bước này, phần quan trọng nhất là Email Address phải khớp với email người gửi.*

openssl req -new -key sender.key -out sender.csr -config openssl.cnf -subj "/C=VN/ST=Thu Duc/L=HCM/O=IT/CN=Nguyen Le Hai Dang/emailAddress=nguyenlehaidang010805@gmail.com"

```
C:\Users\Dang\Desktop\Demo PKI>openssl req -new -key sender.key -out sender.csr -config openssl.cnf -subj "/C=VN/ST=Thu Duc/L=HCM/O=IT/CN=Nguyen Le Hai Dang/emailAddress=nguyenlehaidang010805@gmail.com"
C:\Users\Dang\Desktop\Demo PKI>
```

Hình 3.3: Câu lệnh tạo yêu cầu chứng thực (CSR) chứa thông tin Email .

Bước 4: Cấp phát (Ký) chứng chỉ Dùng Root CA "HaiDang" để ký cho yêu cầu trên.

openssl ca -config openssl.cnf -in sender.csr -out sender.crt -extensions smime_cert -batch

```
C:\Users\Dang\Desktop\Demo PKI>openssl ca -config openssl.cnf -in sender.csr -out sender.crt -extensions smime_cert -batch
Using configuration from openssl.cnf
Check that the request matches the signature
Signature ok
The Subject's Distinguished Name is as follows
countryName           :PRINTABLE:'VN'
stateOrProvinceName   :ASN.1 12:'Thu Duc'
localityName          :ASN.1 12:'HCM'
organizationName      :ASN.1 12:'IT'
commonName            :ASN.1 12:'Nguyen Le Hai Dang'
ERROR:There is already a certificate for /C=VN/ST=Thu Duc/L=HCM/O=IT/CN=Nguyen Le Hai Dang
The matching entry has the following details
Type          :Valid
Expires on    :261130161159Z
Serial Number :1000
File name     :unknown
Subject Name  :/C=VN/ST=Thu Duc/L=HCM/O=IT/CN=Nguyen Le Hai Dang
```

Hình 3.4: Quá trình CA ký phát hành chứng thư số .

Bước 5: Đóng gói chứng chỉ thành file .P12

openssl pkcs12 -export -out sender.p12 -inkey sender.key -in sender.crt -certfile rootCA.crt

```
C:\Users\Dang\Desktop\Demo PKI>openssl pkcs12 -export -out sender.p12 -inkey sender.key -in sender.crt -certfile rootCA.crt
Enter Export Password:
```

Hình 3.5: Xuất chứng thư số và khóa bí mật ra định dạng .P12

Máy sẽ hỏi Export Password: Hãy nhập 123456

```
C:\Users\Dang\Desktop\Demo PKI>openssl pkcs12 -export -out sender.p12 -inkey sender.key -in sender.crt -certfile rootCA.crt
Enter Export Password:
Verifying - Enter Export Password:
```

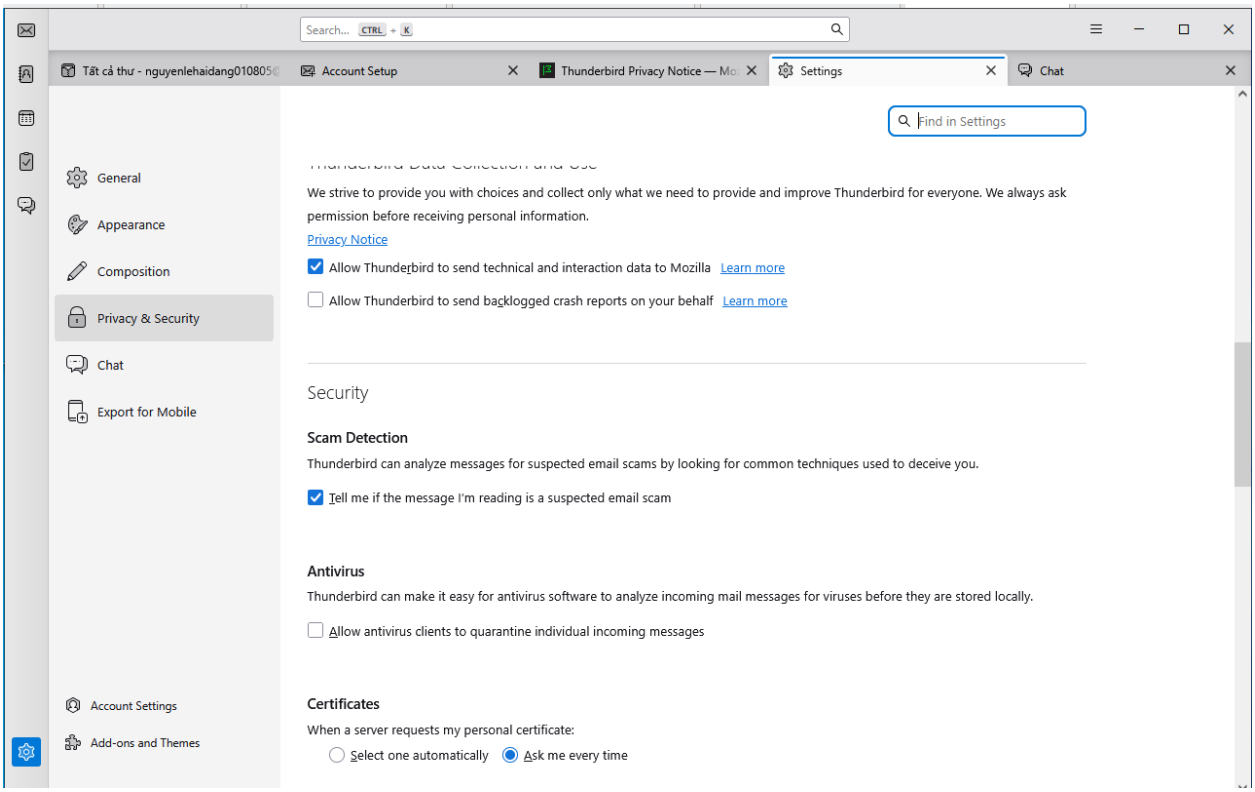
Cấu hình Mozilla Thunderbird (Trên máy ảo)

Bước 1: Cài đặt và Đăng nhập

- Cài Mozilla Thunderbird trên máy ảo.
- Đăng nhập tài khoản nguyenlehaidang010805@gmail.com.

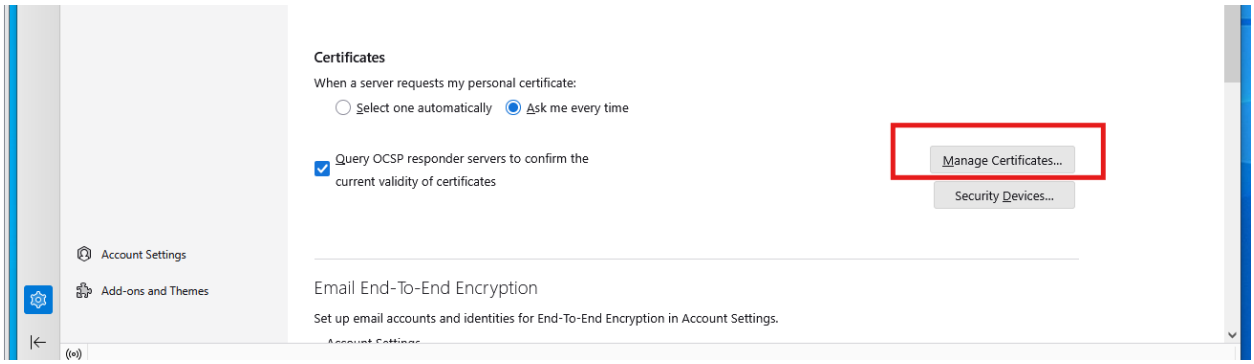
Bước 2: Nhập Root CA vào Thunderbird Thunderbird có kho chứng chỉ riêng (không dùng chung với Windows), nên bạn phải khai báo lại Root CA để nó tin tưởng.

1. Bấm nút Menu (3 gạch ngang) > Settings.



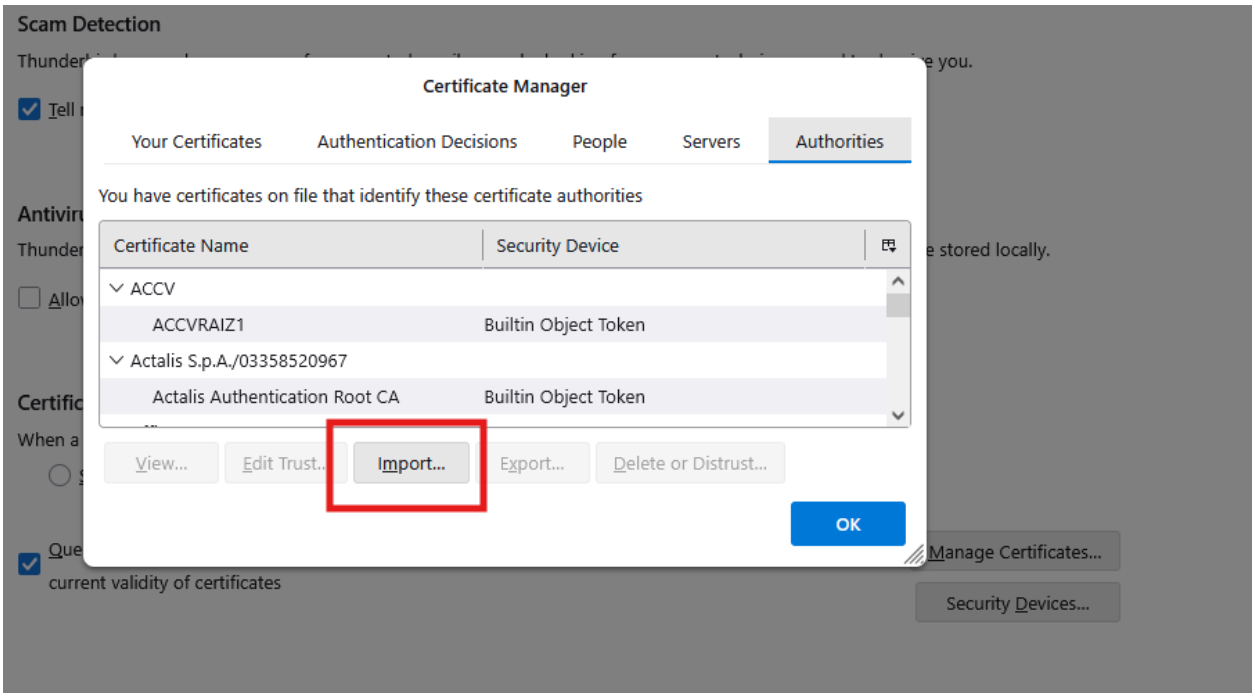
Hình 3.6: Giao diện cài đặt (Settings) trên phần mềm Mozilla Thunderbird .

2. Tìm kiếm từ khóa Certificates > Chọn Manage Certificates.



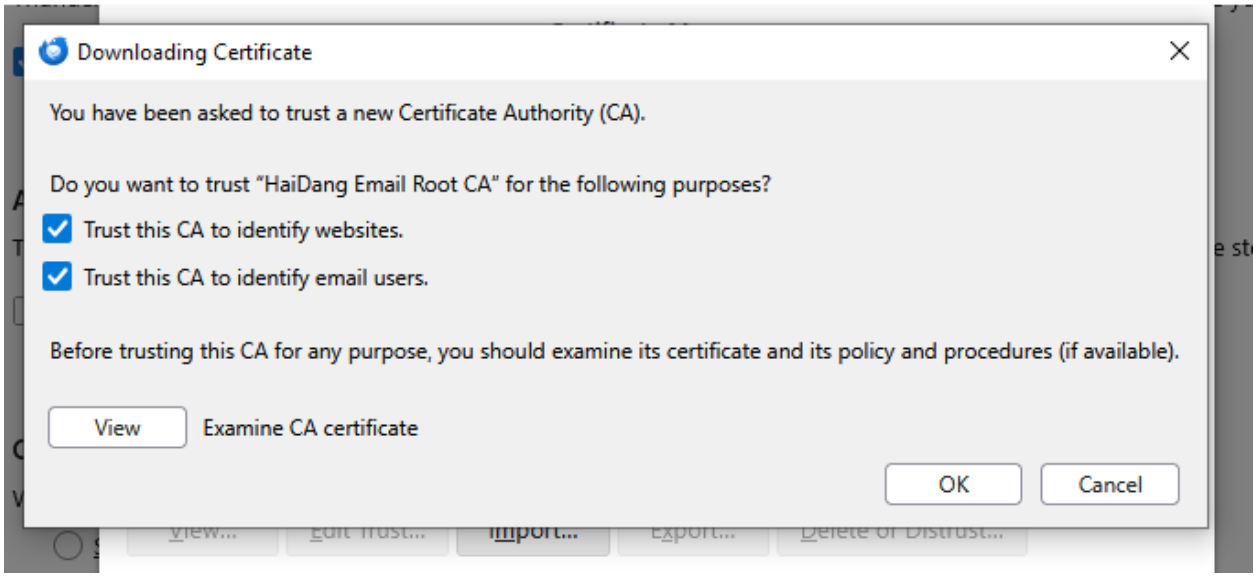
Hình 3.7: Giao diện Trình quản lý chứng thư (Certificate Manager) .

3. Chọn tab Authorities > Bấm Import.



Hình 3.8: Nhập (Import) Root CA vào danh sách tin cậy .

- Chọn file rootCA.crt (trong thư mục DemoPKI).
- Tích chọn "Trust this CA to identify websites" và "Trust this CA to identify email users". > OK.

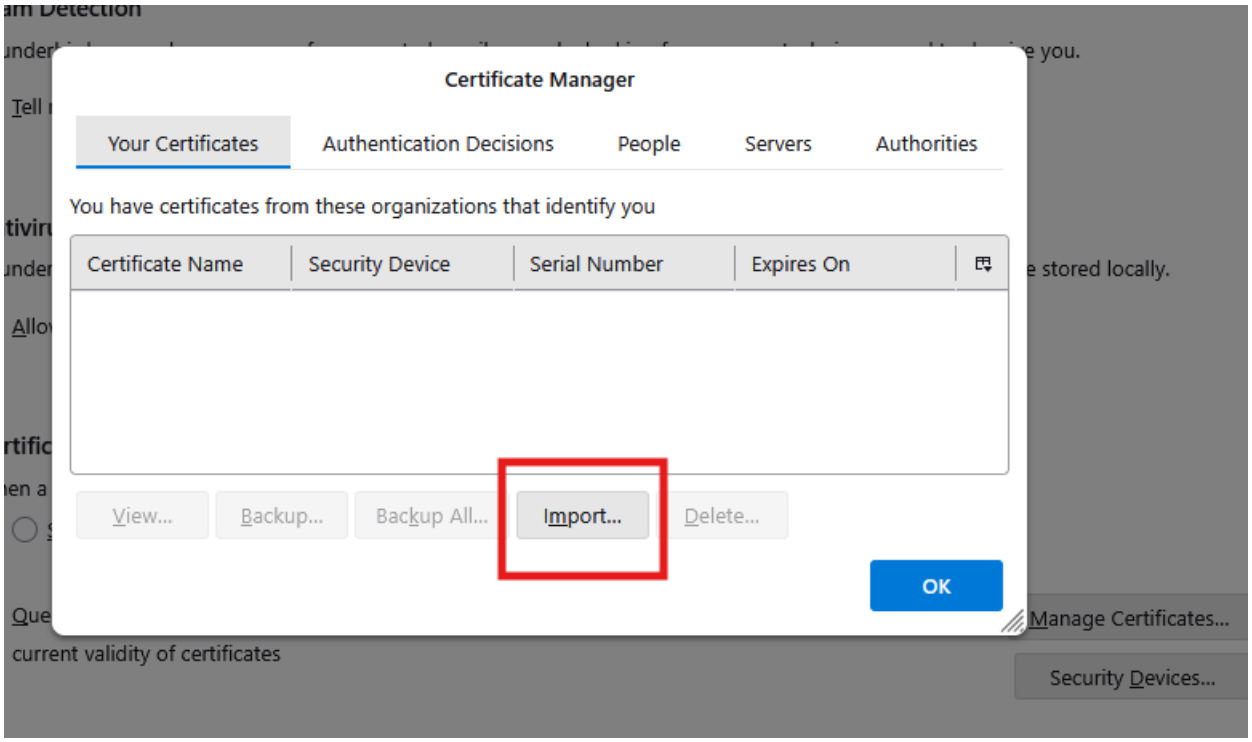


Hình 3.9: Hộp thoại xác nhận tin cậy CA cho xác thực website và email .

Việc tích chọn 'Trust this CA to identify email users' là bắt buộc để Thunderbird tin tưởng các email được ký bởi CA này.

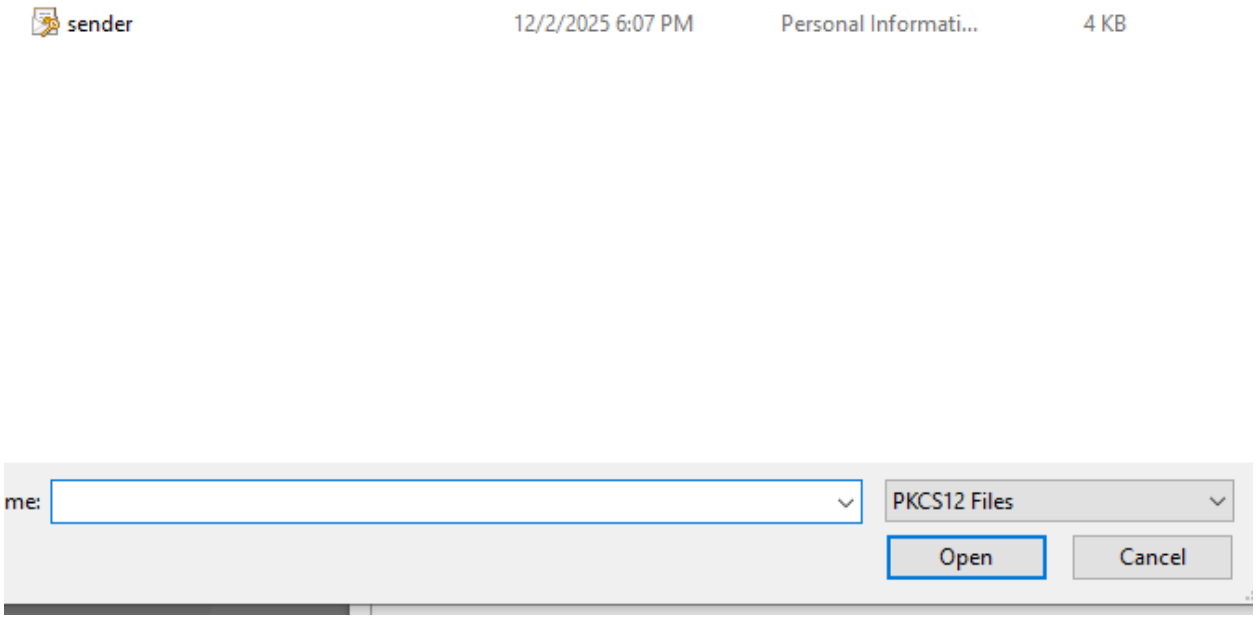
Bước 3: Nhập Chứng chỉ cá nhân (File .P12)

1. Vẫn trong bảng Manage Certificates, chuyển sang tab Your Certificates.

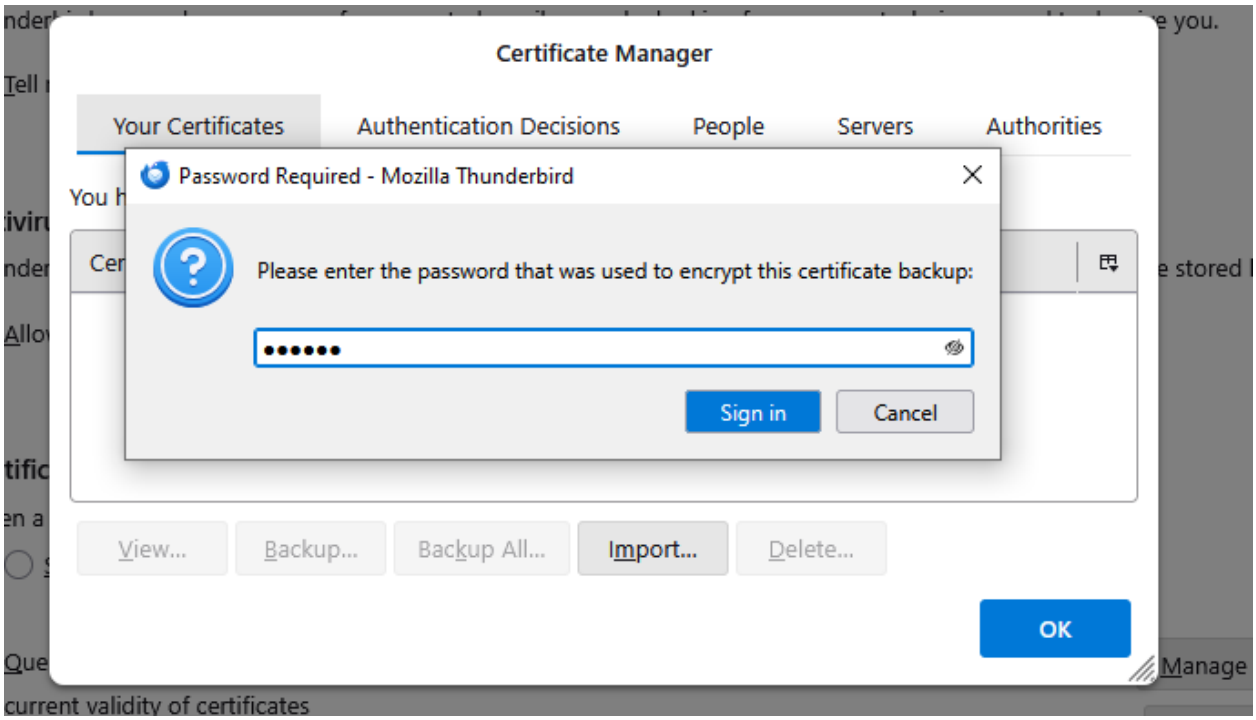


Bấm Import.

2. Chọn file sender.p12 vừa tạo.

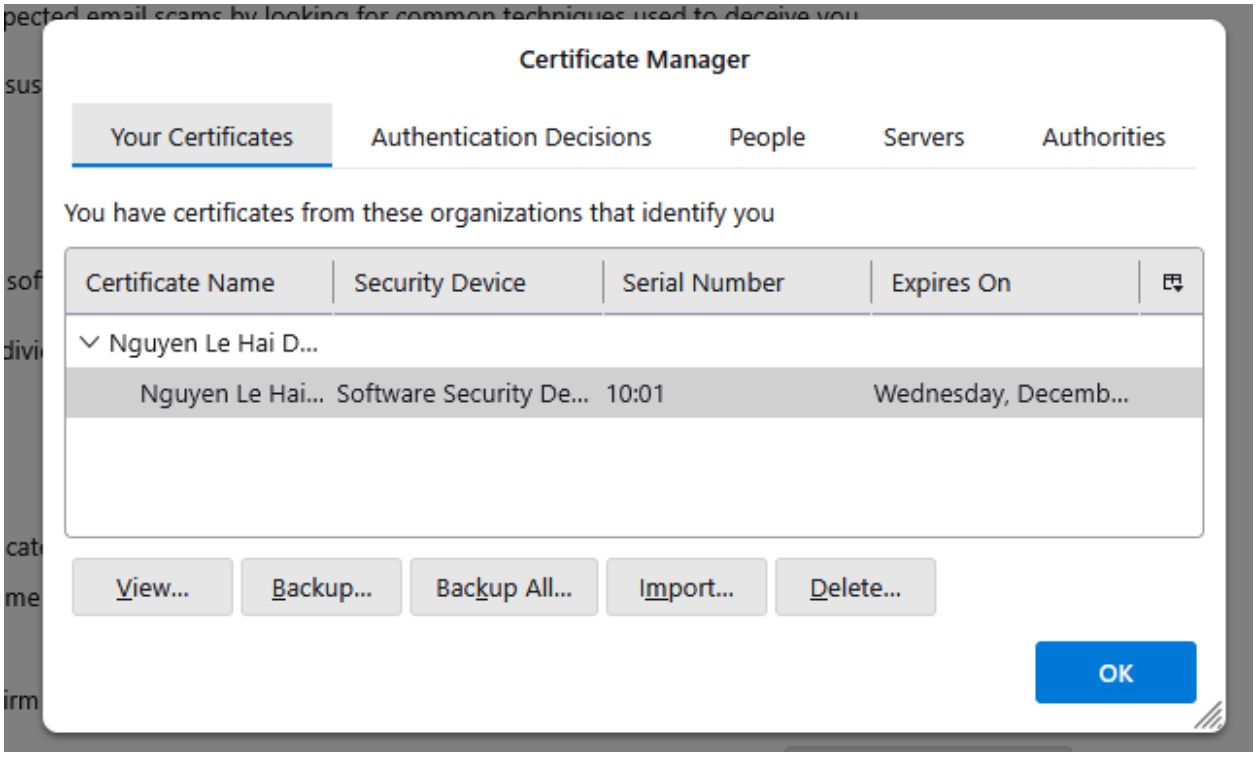


3. Nhập mật khẩu (ví dụ 123456) ta đã đặt lúc nãy.



Hình 3.10: Yêu cầu nhập mật khẩu bảo vệ khi nhập file chứng thư .P12 .

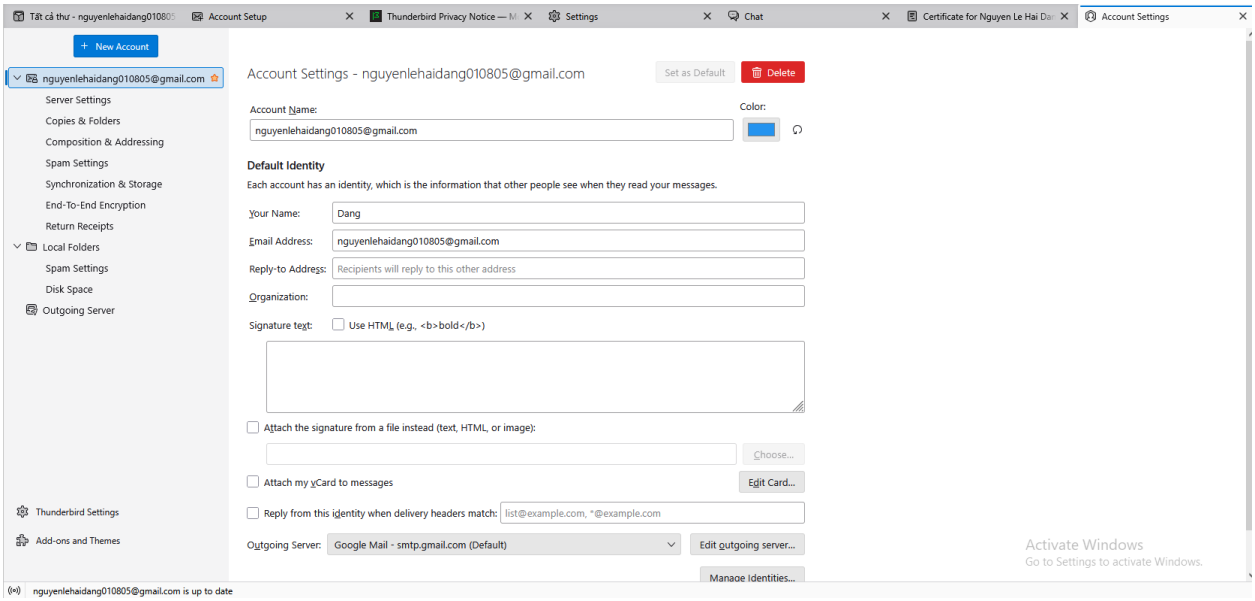
4. Nếu thành công, ta sẽ thấy dòng tên "Nguyen Le Hai Dang" xuất hiện



Hình 3.11: Chứng thư số cá nhân đã được nhập thành công vào Thunderbird .

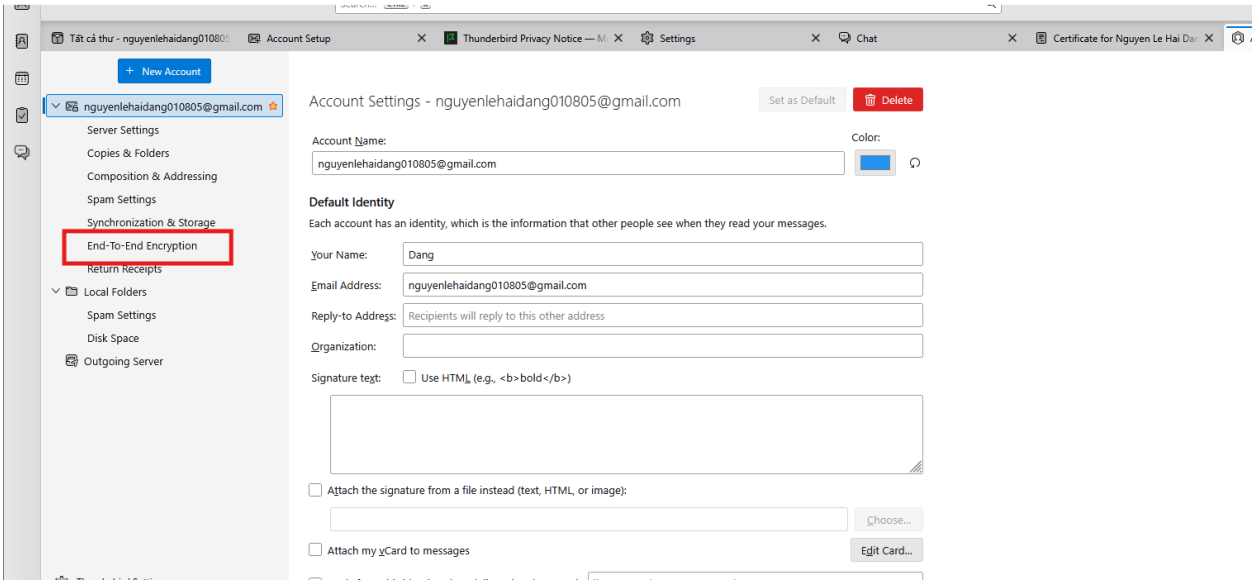
Bước 4: Gán chứng chỉ cho tài khoản Email

1. Vào Account Settings (Cài đặt tài khoản) của email nguyenlehaidang010805.

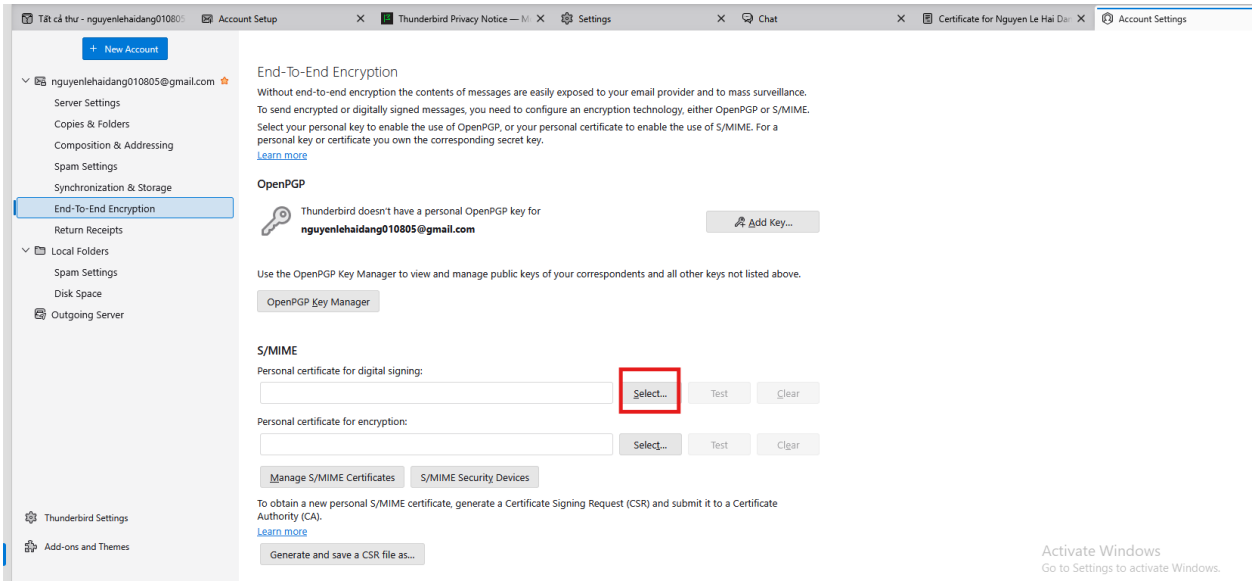


Hình 3.12: Giao diện Cài đặt tài khoản (Account Settings) .

2. Chọn mục End-To-End Encryption ở cột bên trái.

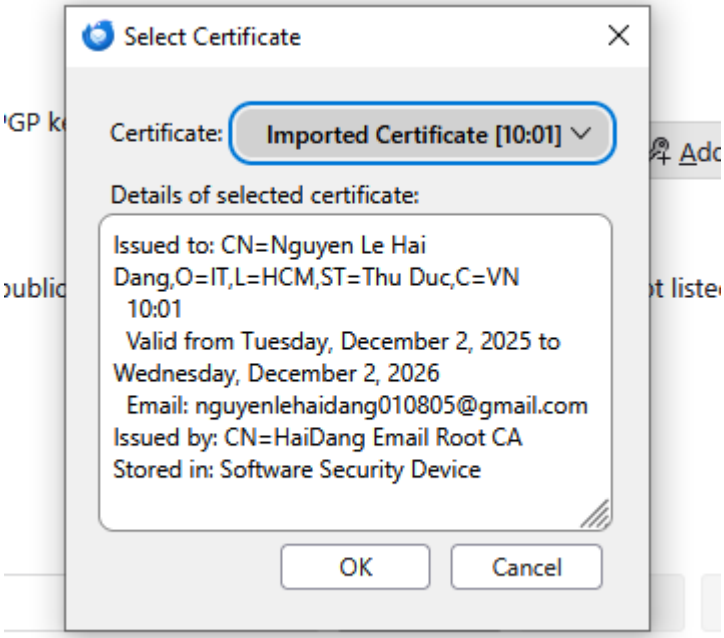


3. Tại phần S/MIME, mục Personal Certificate for Digital Signing, bấm Select.



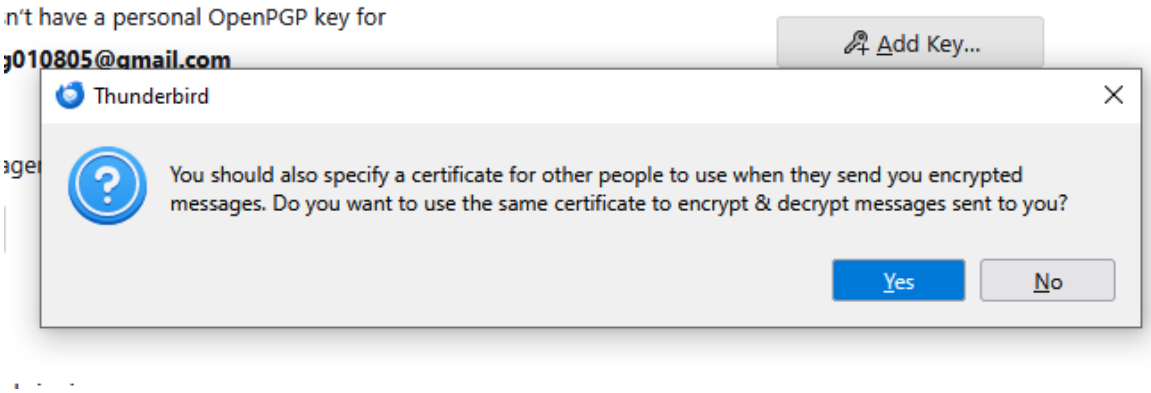
Hình 3.13: Cấu hình Mã hóa đầu cuối (End-To-End Encryption) .

4. Chọn chứng chỉ ta vừa import. Hệ thống sẽ tự hỏi có dùng chứng chỉ này cho việc Mã hóa (Encryption) luôn không? Chọn OK.



Hình 3.14: Chọn chứng thư số dùng để ký và mã hóa .

Chọn Yes

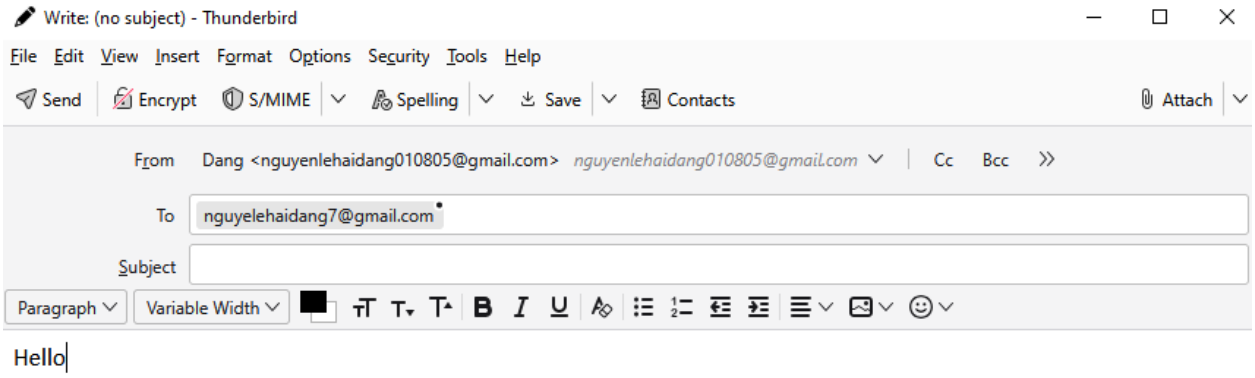


Hình 3.15: Hộp thoại xác nhận sử dụng cùng một chứng thư cho mã hóa và giải mã .

Giai đoạn 3: Thực hiện Gửi Email Ký số (Digital Signature)

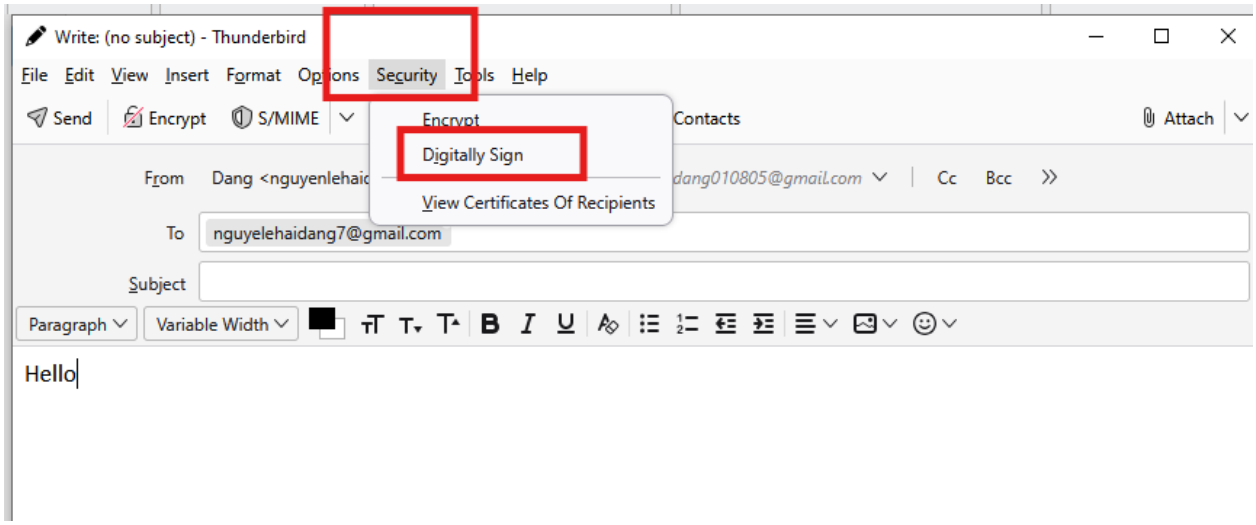
1. Soạn thư: Bấm Write để soạn mail mới.

   Người nhận: nguyenlehaidang7@gmail.com



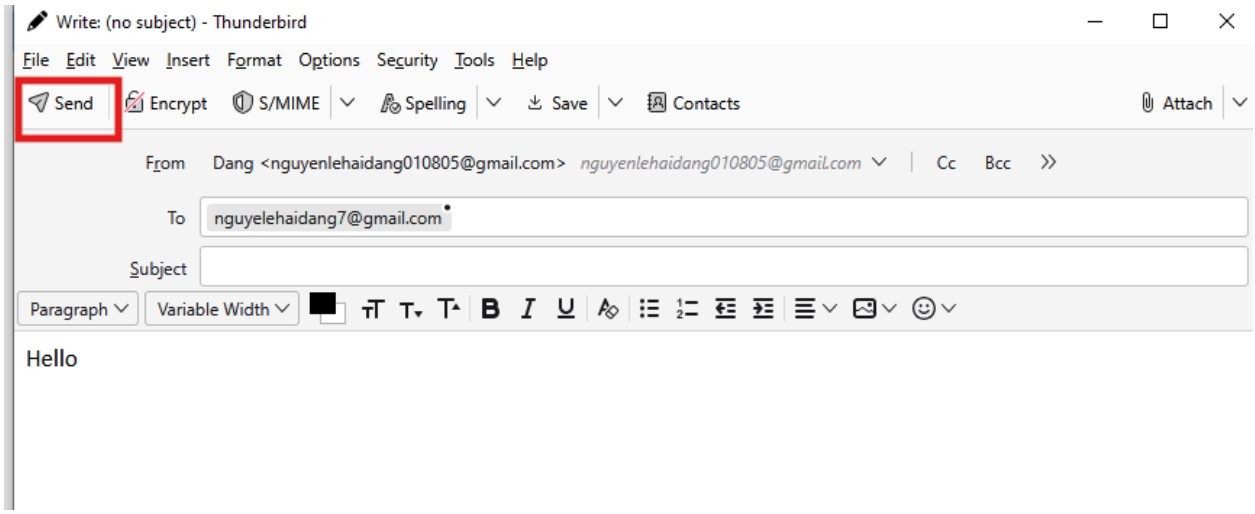
2. Bật Ký số:

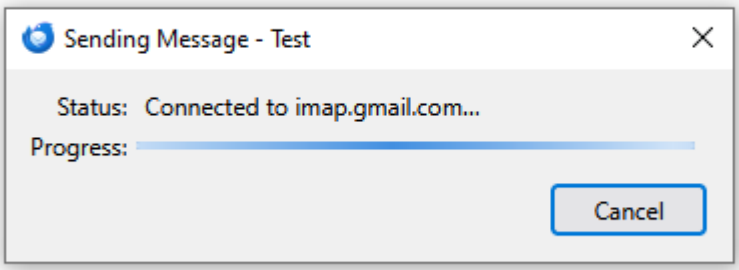
   - Trên thanh menu soạn thảo, bấm vào nút Security.
   - Chọn Digitally Sign This Message.



Hình 3.16: Giao diện soạn thảo email với tùy chọn Ký số (Digitally Sign) .

3. Gửi**:** Bấm Send.



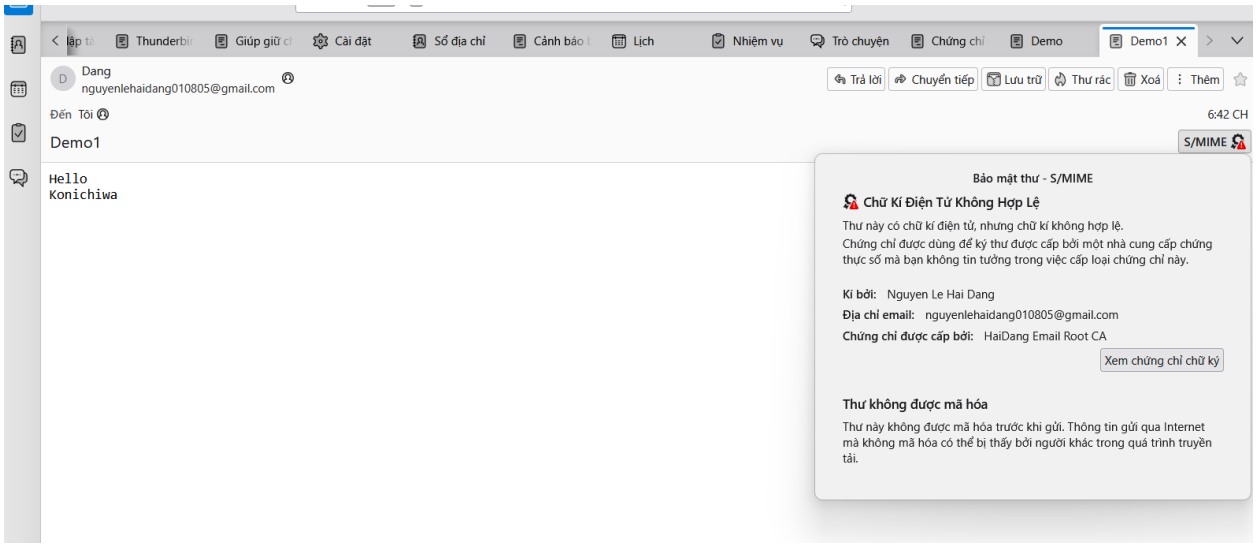


Hình 3.17: Quá trình gửi email đã ký số .

Giai đoạn 4: Kiểm tra trên Máy thật (Người nhận)

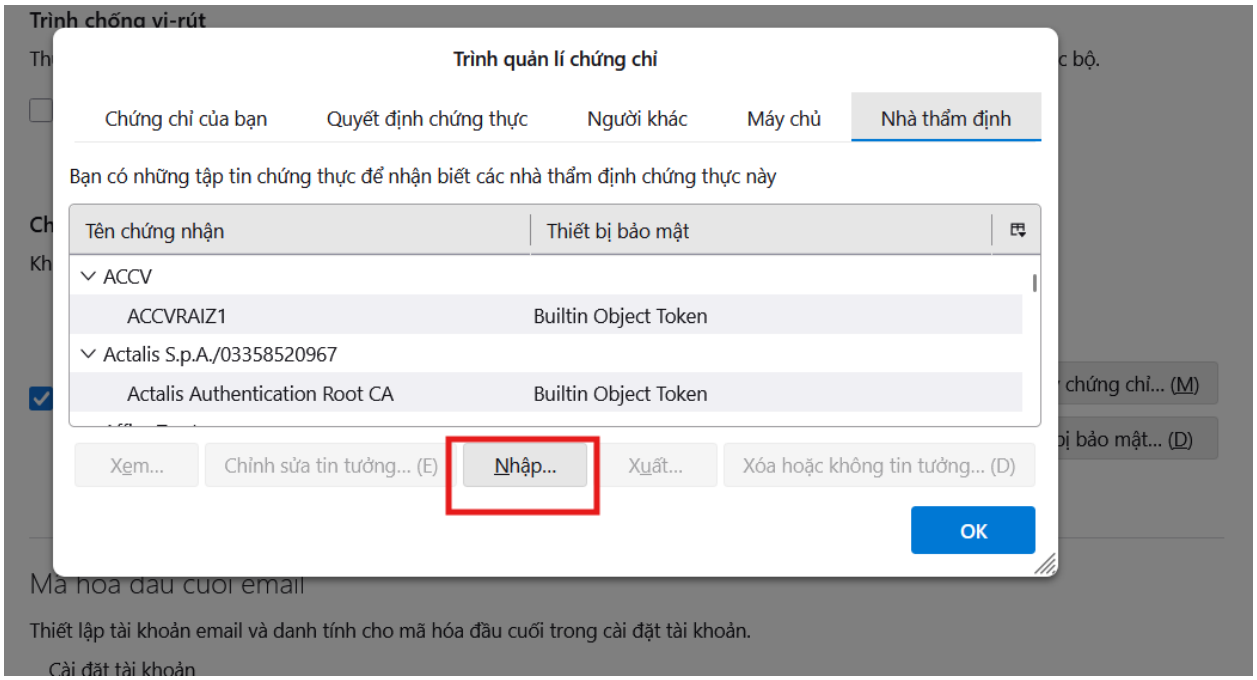
Cài Thunderbird trên Máy thật, đăng nhập mail nguyenlehaidang7@gmail.com.

- Mở email vừa nhận: ta sẽ thấy biểu tượng Lá thư có phong bì đỏ hoặc dấu tích xanh, bấm vào đó nó sẽ hiện: *"Chữ ký điện tử không hợp lệ"*.

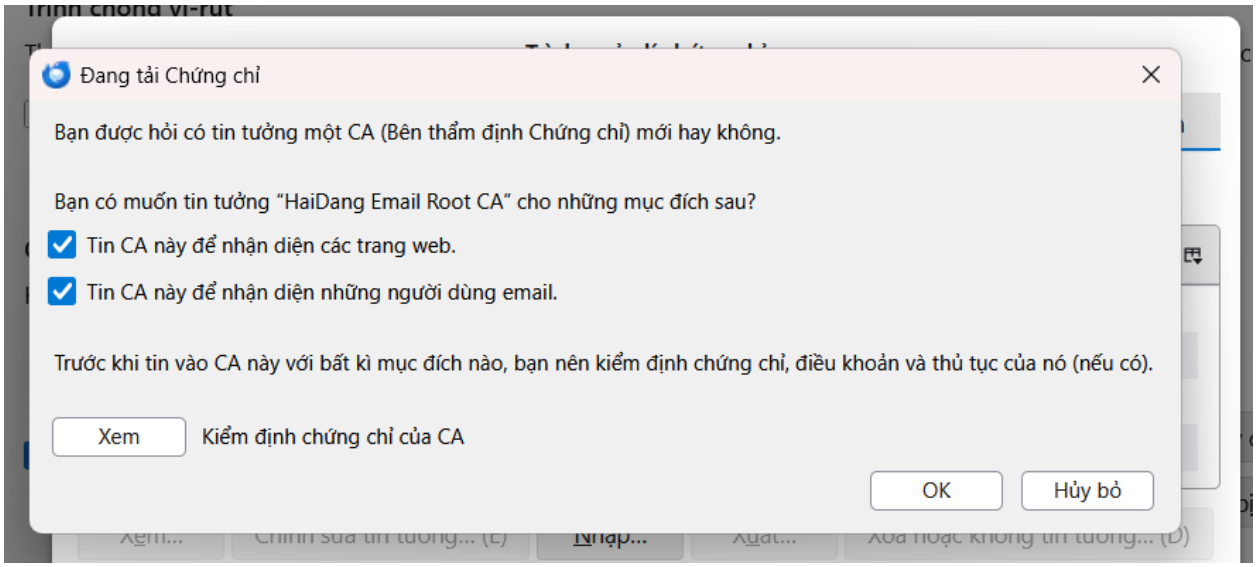


Hình 3.18: Cảnh báo "Chữ ký điện tử không hợp lệ" trên máy người nhận khi chưa tin cậy CA .

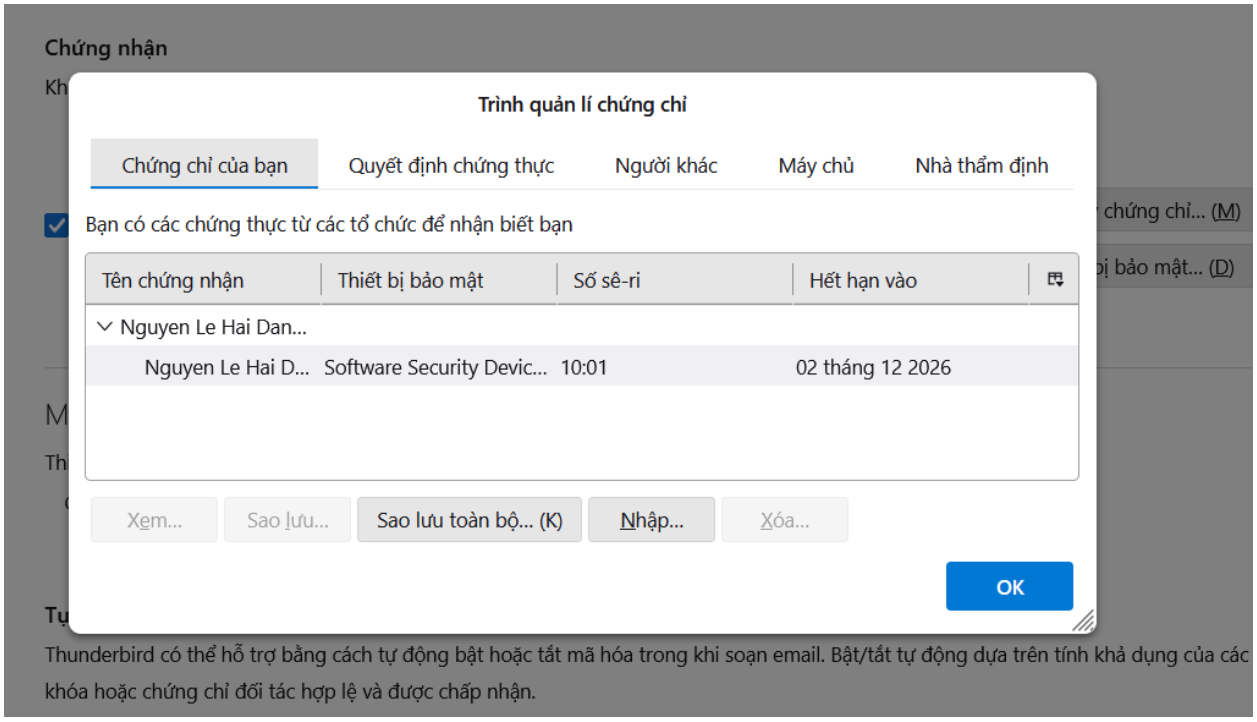
- Import file rootCA.crt vào Thunderbird máy thật (Tab Authorities).



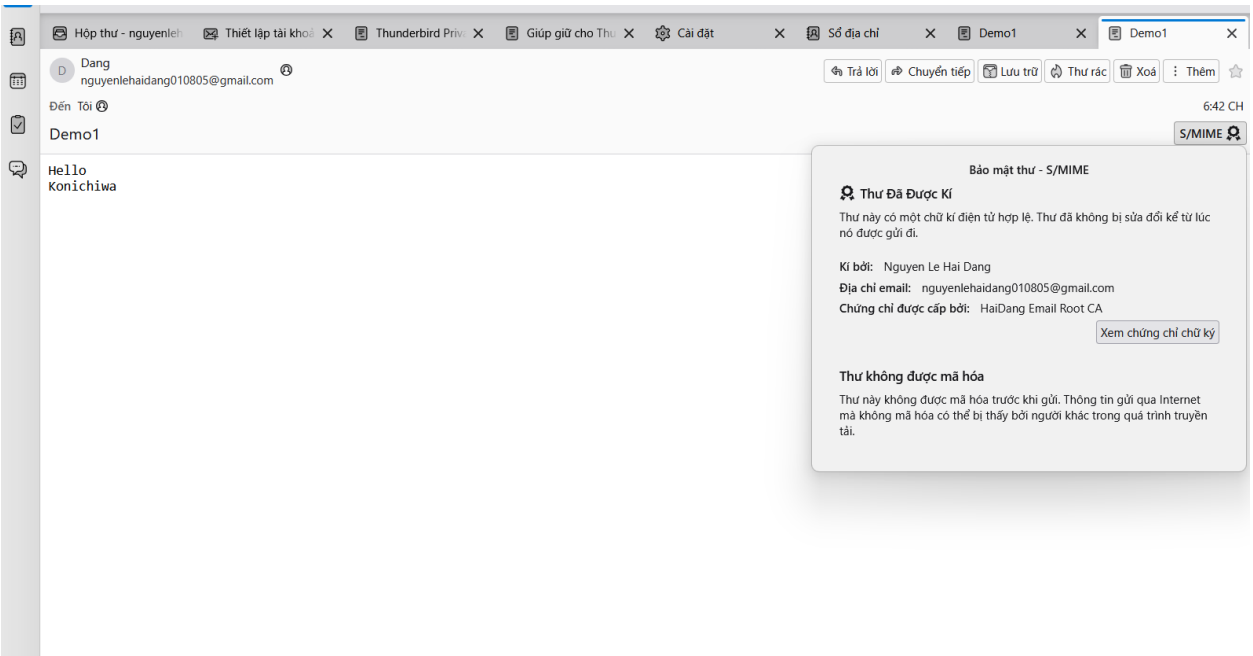
Hình 3.19: Hộp thoại nhập và tin cậy Root CA trên máy người nhận



Hình 3.20: Thông báo thư đã được ký hợp lệ sau khi thiết lập tin cậy .



Kiểm tra lại



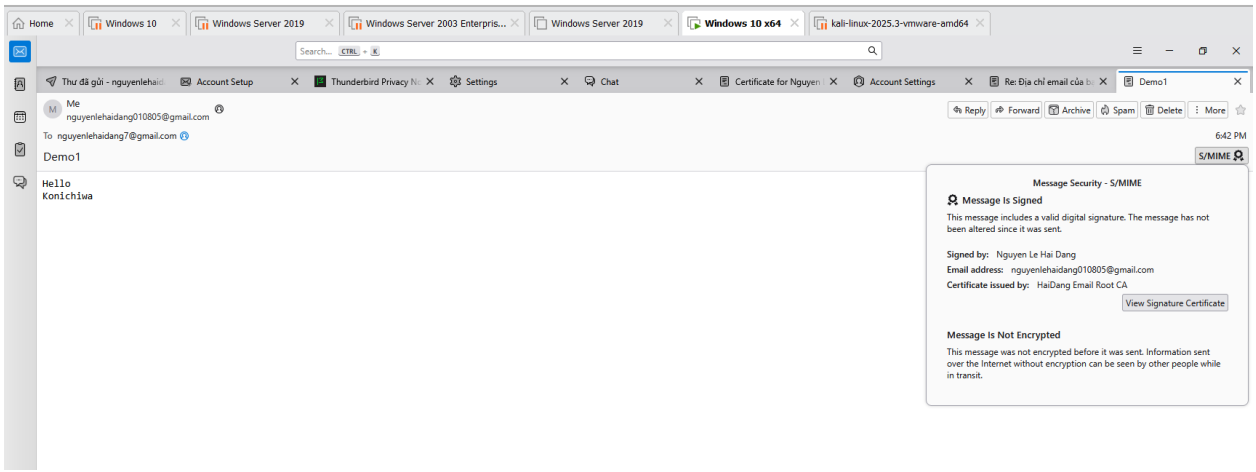
Hình 3.21: Chi tiết bảo mật thư (Message Security) hiển thị thông tin người ký .

Check ngay trên Thunderbird máy ảo (Gửi cho chính mình).

- Gửi từ nguyenlehaidang010805 đến nguyenlehaidang010805.

- Mở hộp thư Sent hoặc Inbox. Bấm vào thư.

- Sẽ thấy thanh thông báo: "This message is signed...". Bấm vào xem chi tiết chứng chỉ.

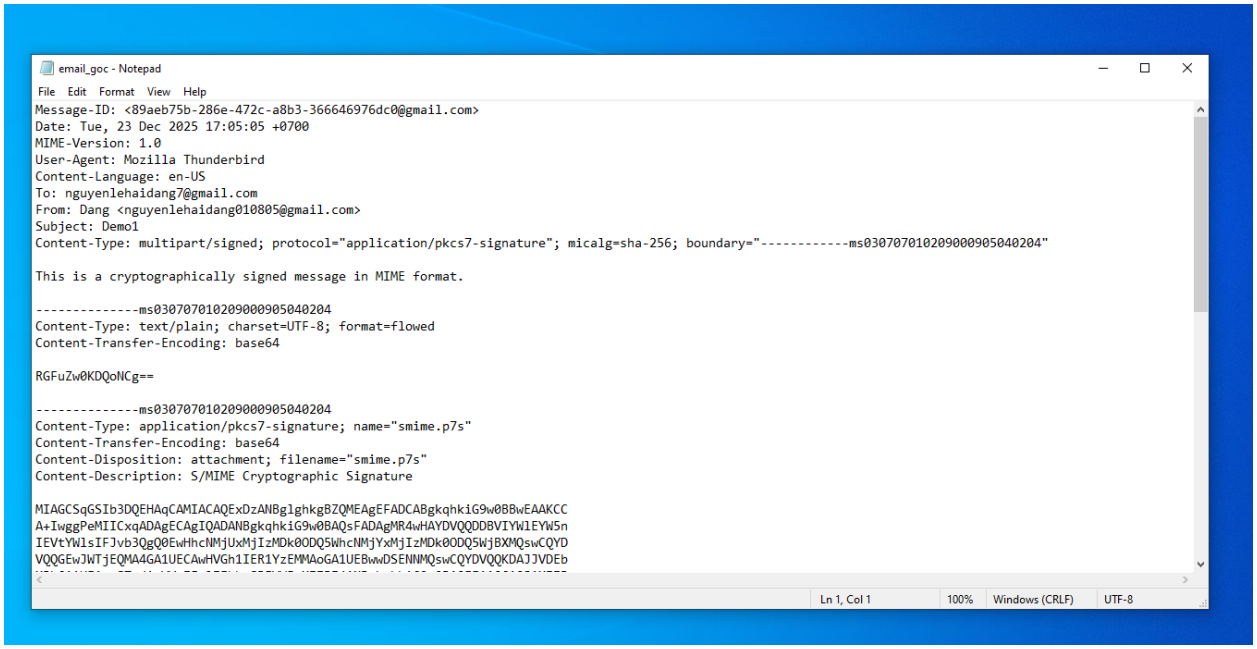


Kiểm tra tính vẹn toàn

Bước 1: Lưu một email đã ký ra máy

- Mở Thunderbird trên máy ảo, chọn một email ta đã gửi thành công và có chữ ký số
- Bấm vào menu (3 gạch ngang) > File > Save As > File.

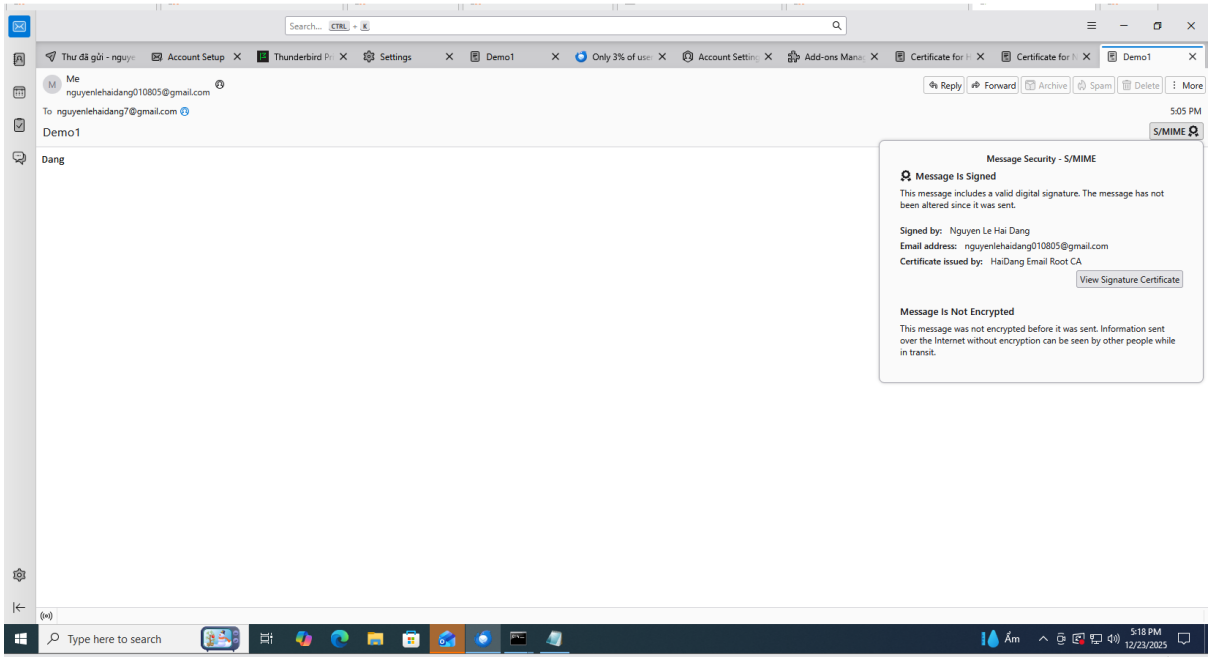
- Lưu ra Desktop với tên email_goc.eml.



Hình 3.22: Mã nguồn email (định dạng MIME) trước khi bị chỉnh sửa .

Bước 2: Chụp ảnh "Trước khi tấn công" (Hợp lệ)

1. Mở Thunderbird.
2. Vào File > Open Saved Message > Chọn file email_signed.eml.
3. Bạn sẽ thấy nội dung thư là chữ "Dang".



Bước 3: Thực hiện "Tấn công sửa đổi" (Tampering)

Đây là bước thú vị nhất. Ta sẽ đóng vai Hacker sửa đổi nội dung file này.

1. Click chuột phải vào file email_signed.eml > Open with > Notepad.
2. Tìm đến dòng chứa nội dung (Dòng thứ 15 trong đoạn mã):

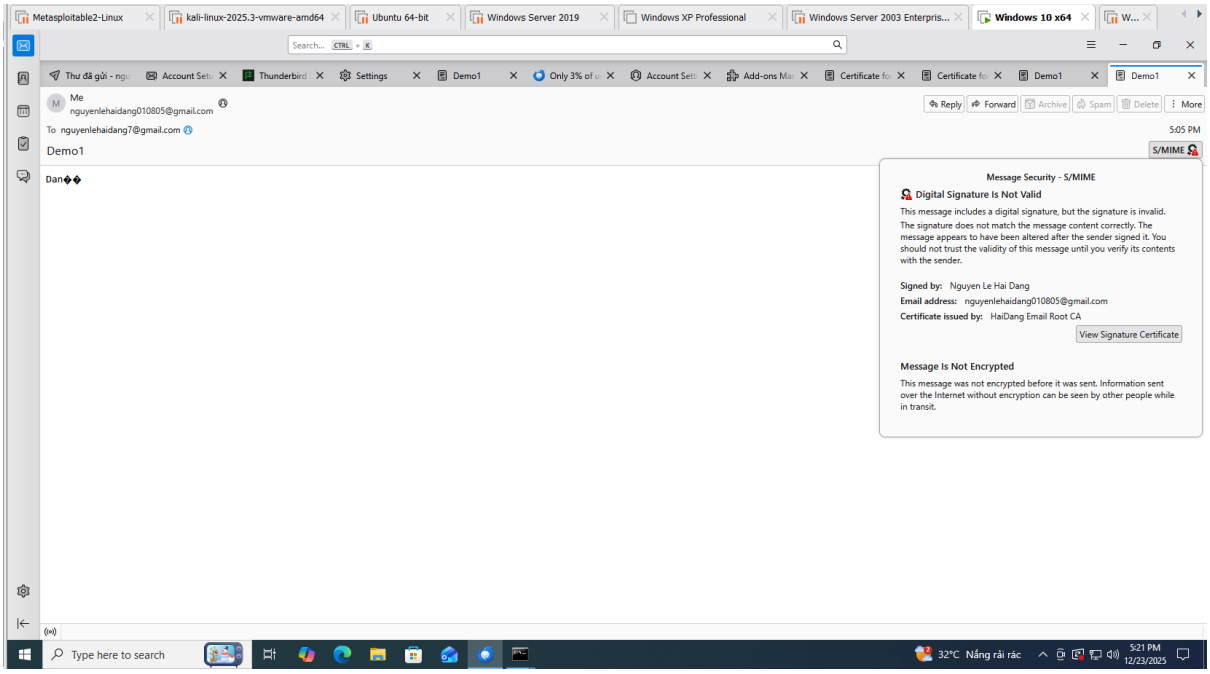
RGFu990KDQoNCg==

```
This is a cryptographically signed message in MIME format.

--------------ms030707010209000905040204
Content-Type: text/plain; charset=UTF-8; format=flowed
Content-Transfer-Encoding: base64

RGFu990KDQoNCg==

--------------ms030707010209000905040204
Content-Type: application/pkcs7-signature; name="smime.p7s"
Content-Transfer-Encoding: base64
Content-Disposition: attachment; filename="smime.p7s"
Content-Description: S/MIME Cryptographic Signature

MIAGCSqGSIb3DQEHAqCAMIACAQExDzANBglghkgBZQMEAgEFADCABgkqhkiG9w0BBwEAAKCC
A+IwggPeMIICxqADAgECAgIQADANBgkqhkiG9w0BAQsFADAgMR4wHAYDVQQDDBVIYWlEYW5n
IEVtYWlsIFJvb3QgQ0EwHhcNMjUxMjIzMDk0ODQ5WhcNMjYxMjIzMDk0ODQ5WjBXMQswCQYD
VQQGEwJWTjEQMA4GA1UECAwHVGh1TFR1YzEMMAoGA1UEBwwDSFNNMQswCQYDVQQKDAJJVDEh
```

Hình 3.23: Quá trình can thiệp sửa đổi nội dung bản tin bằng Notepad .

Bước 4: Phát hiện tấn công

1. Quay lại Thunderbird, mở lại file email_signed.eml vừa sửa.
2. Kết quả: Thunderbird sẽ ngay lập tức báo lỗi chéo đỏ hoặc thông báo: "The message signature is not valid" (hoặc *Message has been altered*).



Hình 3.24: Cảnh báo "Chữ ký số không hợp lệ" (Digital Signature Is Not Valid) sau khi nội dung bị thay đổi.

Kết luận phần thực nghiệm:

Thông qua quá trình thực nghiệm tại Chương III, đề tài đã hiện thực hóa thành công các nguyên lý lý thuyết của hệ thống PKI vào một ứng dụng cụ thể là bảo mật thư điện tử chuẩn S/MIME. Bằng việc sử dụng bộ công cụ OpenSSL để mô phỏng vai trò của CA và phần mềm Mozilla Thunderbird làm client, chúng ta đã xây dựng hoàn chỉnh quy trình cấp phát, cài đặt và sử dụng chứng thư số, qua đó minh chứng tính khả thi của việc triển khai PKI trong môi trường thực tế.

Kết quả thực nghiệm đã làm sáng tỏ hai khía cạnh quan trọng của an toàn thông tin. Thứ nhất, cơ chế ký số đã hoạt động hiệu quả trong việc xác thực danh tính người gửi và đảm bảo tính chống chối bỏ, giúp người nhận dễ dàng phân biệt được thư tín chính chủ với các nỗ lực giả mạo. Thứ hai, và quan trọng hơn cả, kịch bản tấn công sửa đổi nội dung (Tampering) đã chứng minh sức mạnh của hàm băm trong việc bảo vệ tính toàn vẹn dữ liệu. Hệ thống đã ngay lập tức phát hiện và cảnh báo khi bản tin bị can thiệp dù chỉ là một ký tự nhỏ nhất, khẳng định rằng PKI là một giải pháp phòng vệ vững chắc trước các rủi ro an ninh mạng phổ biến đối với hệ thống thư điện tử ngày nay.

CHƯƠNG IV: KẾT LUẬN & HƯỚNG PHÁT TRIỂN

4.1. Kết luận

Trong bối cảnh chuyển đổi số đang diễn ra mạnh mẽ trên toàn cầu và đặc biệt tại Việt Nam, vấn đề an toàn thông tin không còn là một lựa chọn mà là yếu tố sống còn đối với mọi tổ chức và cá nhân. Qua quá trình nghiên cứu về Cơ sở hạ tầng khóa công khai (PKI) và các ứng dụng liên quan trong đề tài này, chúng ta có thể rút ra những kết luận quan trọng sau:

Thứ nhất, Mật mã học bất đối xứng đóng vai trò là nền tảng kỹ thuật không thể thay thế. Khả năng giải quyết vấn đề phân phối khóa và đảm bảo tính chống chối bỏ (non-repudiation) là ưu điểm vượt trội của hệ mật này so với mật mã đối xứng truyền thống. Các thuật toán như RSA, ECC hay hàm băm SHA-256 đã tạo nên lớp bảo vệ vững chắc cho dữ liệu số.

Thứ hai, PKI là hạ tầng của niềm tin (Trust Infrastructure). Nghiên cứu cho thấy PKI không chỉ đơn thuần là tập hợp các máy chủ và phần mềm, mà là một hệ thống tổng thể bao gồm cả hành lang pháp lý, quy trình quản lý và yếu tố con người. Tại Việt Nam, sự phát triển của hệ thống các nhà cung cấp dịch vụ chứng thực chữ ký số (CA) công cộng và chuyên dùng đã tạo điều kiện thuận lợi cho việc triển khai Chính phủ điện tử, thuế điện tử và giao dịch ngân hàng số.

Thứ ba, Tính ứng dụng thực tiễn cao. Thông qua việc tìm hiểu ứng dụng S/MIME (Secure/Multipurpose Internet Mail Extensions), đề tài đã minh chứng cách PKI bảo vệ người dùng cuối khỏi các nguy cơ tấn công như Phishing (lừa đảo), Eavesdropping (nghe lén) và giả mạo email. Đây là giải pháp thiết thực để bảo vệ luồng thông tin trong môi trường doanh nghiệp.

Tóm lại, PKI đã, đang và sẽ tiếp tục là xương sống của nền kinh tế số, đảm bảo cho các giao dịch điện tử diễn ra an toàn, tin cậy và có giá trị pháp lý.

4.2. Hướng phát triển

Căn cứ vào những hạn chế kỹ thuật còn tồn tại và sự chuyển dịch mạnh mẽ của xu hướng công nghệ toàn cầu, đề tài đề xuất bốn định hướng nghiên cứu chiến lược nhằm nâng cao năng lực của hệ thống bảo mật trong tương lai. Ưu tiên hàng đầu và cấp thiết nhất là lĩnh vực Mật mã Hậu lượng tử (Post-Quantum Cryptography - PQC). Trong bối cảnh sức mạnh tính toán của máy tính lượng tử đang ngày càng hoàn thiện và đặt ra mối đe dọa trực tiếp đến tính an toàn của các thuật toán kinh điển như RSA hay ECC, việc nghiên cứu lộ trình chuyển đổi hạ tầng PKI hiện hữu sang các tiêu chuẩn kháng lượng tử – điển hình là CRYSTALS-Kyber hay CRYSTALS-Dilithium theo khuyến nghị của NIST – là bước đi sống còn để đảm bảo an ninh thông tin trong dài hạn.

Song song với việc nâng cấp thuật toán, khía cạnh vận hành cũng cần được cải tiến thông qua Tự động hóa quản lý vòng đời chứng thư. Sự bùng nổ theo cấp số nhân của các thiết bị kết nối và kiến trúc Microservices đã khiến phương thức quản trị thủ công trở nên bất khả thi. Do đó, hướng nghiên cứu cần tập trung sâu vào việc triển khai giao thức ACME nhằm tự động hóa khép kín quy trình từ cấp phát, cài đặt đến gia hạn, giúp triệt tiêu các rủi ro gián đoạn dịch vụ do sai sót của con người. Bên cạnh đó, nhằm đáp ứng nhu cầu của hàng tỷ thiết bị thông minh, việc phát triển PKI cho Internet vạn vật (IoT PKI) cũng là một hướng đi trọng tâm. Các nghiên cứu cần hướng tới mô hình "Lightweight PKI" – tối ưu hóa quy trình xác thực để phù hợp với các thiết bị có tài nguyên phần cứng hạn chế về pin và chip xử lý, đảm bảo an toàn ngay từ khâu sản xuất.

Cuối cùng, một hướng đi đột phá mang tính cấu trúc là sự tích hợp giữa PKI và công nghệ Blockchain để hình thành mô hình PKI phi tập trung (Decentralized PKI). Thay vì phụ thuộc hoàn toàn vào niềm tin đặt tại một tổ chức CA trung gian duy nhất, mô hình này tận dụng mạng lưới Blockchain và Danh tính phi tập trung (DID) để thực hiện xác thực. Cách tiếp cận này không chỉ giúp hệ thống loại bỏ được các điểm lỗi – nơi mà sự cố tại một điểm có thể làm tê liệt toàn bộ hệ thống – mà còn tăng cường đáng kể tính minh bạch và khả năng kiểm soát danh tính của người dùng.

DANH MỤC TÀI LIỆU THAM KHẢO

[1]. Cooper, D., & Santesson, S. (2008, May). Internet X.509 Public Key Infrastructure Certificate and Certificate Revocation List (CRL) Profile (RFC 5280). https://datatracker.ietf.org/doc/html/rfc5280

[2]. SecurityDaily. (2024, Jan 15). Tổng quan về hạ tầng khóa công khai PKI và ứng dụng trong doanh nghiệp. https://securitydaily.net/tong-quan-ve-ha-tang-khoa-cong-khai-pki

[3]. WhiteHat. (2023, Dec 10). Tìm hiểu về S/MIME và cách thức bảo mật Email doanh nghiệp. https://whitehat.vn/threads/tim-hieu-ve-s-mime-bao-mat-email.16542/

[4]. Microsoft Learn. (2024, Mar 05). Public Key Infrastructure (PKI) Design and Hierarchy. https://learn.microsoft.com/en-us/windows-server/identity/ad-cs/plan-design/designing-a-public-key-infrastructure

[5]. Viblo, T. (2024, Feb 20). Mã hóa bất đối xứng và Ứng dụng trong HTTPS - Phần 1: Lý thuyết cơ bản. https://viblo.asia/p/ma-hoa-bat-doi-xung-va-ung-dung-trong-https-phan-1-ly-thuyet-co-ban

[6]. NIST. (2024, Aug 13). Post-Quantum Cryptography Standardization. https://csrc.nist.gov/projects/post-quantum-cryptography